MACÍAS
SÁNCHEZ
CONSULTORES

KIT DE HERRAMIENTAS LOPDP · ECUADOR

Guía de uso para el Delegado de Protección de Datos

Rol y límites del DPD, mapeo de la empresa, recorrido de los datos, ocho herramientas en orden de uso, catálogo de servicios, honorarios, informe a la gerencia y normas ISO para el DPD en Ecuador.

Abg. Mariano X. Macías Sánchez
Consultor en Protección de Datos Personales · Matrícula profesional 09-2022-736

Versión 1.4 · noviembre de 2026
Uso profesional · material de apoyo

PRESENTACIÓN

Cómo usar esta guía

Esta guía acompaña al **Kit de herramientas LOPDP**: nueve herramientas, cada una en versión documento (Word o Excel) y versión web interactiva, para que el Delegado de Protección de Datos (DPD) en Ecuador cotice, diagnostique, documente, evalúe y supervise el cumplimiento de la **Ley Orgánica de Protección de Datos Personales (LOPDP)**, su Reglamento General (RGLOPDP) y la normativa de la **Superintendencia de Protección de Datos Personales (SPDP)**.

Las herramientas están **numeradas en el orden en que se usan**: la 01 se usa primero y la 09 al final. Cada capítulo responde qué herramienta usar, cuándo, cómo, por qué es necesaria según el caso y cómo explicarla al cliente con precisión técnica y en lenguaje claro.

Si necesita…	Vaya a
Ver las nueve herramientas y cuál usar según el caso	Capítulo 1
Elegir qué servicios ofrecer y consultar definiciones	Capítulo 9.1
Repasar el marco normativo y el vocabulario técnico	Capítulo 2
Entender qué hace y qué no hace el DPD: asesorar y supervisar, no implementar	Capítulo 3
Ver el roadmap de la gestión del DPD en la empresa	Capítulo 3.7
Planificar una intervención completa	Capítulo 4
Preparar la primera reunión, las propuestas, los honorarios y la campaña comercial	Capítulo 5
Mapear la empresa antes del diagnóstico de madurez	Capítulo 6
Identificar qué datos trata una empresa	Capítulo 7
Explicar al gerente el recorrido de los datos, el encargo y la transferencia	Capítulo 8
Usar cada herramienta paso a paso	Capítulo 9
Explicar las áreas de tratamiento (RAT y madurez)	Capítulo 10
Presentar el informe a la gerencia	Capítulo 11
Mantener el cumplimiento en el tiempo	Capítulo 12
Decidir qué normas ISO conocer o implementar	Capítulo 13
Revisar recomendaciones para el ejercicio del DPD	Capítulo 14
Saber qué cubre el kit de las guías de la SPDP y qué falta	Capítulo 15

ATENCIÓN

Las citas normativas de esta guía se tomaron de la matriz **BASE-LEGAL.md** del kit. Varias provienen de resúmenes profesionales y no del texto oficial: contrástelas con el Registro Oficial antes de emitir un criterio a un cliente. Las escalas, umbrales y ponderaciones que no provienen de la norma se identifican como **criterio propio**.

Contenido

El kit en una página 5

1.1 Qué herramienta usar según el caso 6

Marco de actuación del DPD en Ecuador 7

2.1 Las normas que usará todos los días 7

2.2 El principio que ordena todo: responsabilidad proactiva . . . 7
2.3 Vocabulario esencial para hablar con el cliente . . . 8
El rol del DPD: asesorar y supervisar, no implementar . . . 9
3.1 Funciones del DPD . . . 9
3.2 Adecuación, implementación y supervisión . . . 9
3.3 Quién hace qué . . . 10
3.4 Responsabilidades y obligaciones del DPD . . . 10
3.5 Límites del DPD . . . 10
3.6 Si usted adecúa y luego será el DPD . . . 11
3.7 Roadmap de la gestión del DPD en la empresa . . . 11
Metodología de intervención . . . 13
Abordaje al cliente y propuestas . . . 15
5.1 Antes de la primera reunión . . . 15
5.2 Guion de la primera reunión (30 minutos) . . . 15
5.3 Objeciones frecuentes . . . 15
5.4 Cómo presentar la propuesta de evaluación . . . 16
5.5 Cómo presentar la propuesta de control . . . 16
5.6 Cómo fijar los honorarios . . . 17
5.7 Kit comercial: carta de presentación y campaña de correos . . . 17
Mapeo inicial de la empresa . . . 19
6.1 Qué buscar antes de la primera entrevista . . . 19
6.2 Ficha de perfil de la empresa . . . 19
6.3 Matriz de áreas y dominios . . . 19
6.4 Señales observables . . . 20
6.5 Del mapeo al diagnóstico . . . 20
Cómo identificar los datos que trata una empresa . . . 22
7.1 Las estructuras de referencia . . . 22
7.2 Las ocho preguntas del inventario (NIST ID.IM-P) . . . 22
7.3 Método de levantamiento en seis pasos . . . 22
El recorrido de los datos: encargo y transferencia . . . 24
8.1 Las seis etapas . . . 24
8.2 Encargo frente a comunicación o transferencia . . . 24
8.3 Caso 1 · María compra en la ferretería . . . 25
8.4 Caso 2 · Juan es contratado . . . 26
8.5 Caso 3 · Un visitante y las cámaras . . . 26
Las herramientas paso a paso . . . 28

9.1 Herramienta 01 · Catálogo de servicios y glosario . . . 28
9.2 Herramienta 02 · Calculadora de honorarios . . . 29
9.3 Herramienta 03 · Nivel de madurez . . . 29
9.4 Herramienta 04 · Registro de actividades de tratamiento . . . 31
9.5 Herramienta 05 · Evaluación de gran escala . . . 32
9.6 Herramienta 06 · Interés legítimo . . . 33
9.7 Herramienta 07 · Evaluación de impacto . . . 34
9.8 Herramienta 08 · Kit de plantillas . . . 35
9.9 Herramienta 09 · Kit de vulneraciones . . . 36

Áreas de tratamiento: cómo explicarlas . . . 38

10.1 Macroprocesos del RAT . . . 38
10.2 Dominios del diagnóstico de madurez . . . 38

El informe a la gerencia . . . 40

11.1 Estructura del informe de evaluación general . . . 40
11.2 Matriz de soportes . . . 40
11.3 La presentación oral (20 minutos) . . . 41
11.4 Carpeta de evidencias . . . 41

Control y mejora continua . . . 42

Normas ISO para el ejercicio del DPD . . . 43

Recomendaciones para el ejercicio del DPD en Ecuador . . . 45

Contraste con las guías de la SPDP . . . 46

15.1 Guía v2 de gestión de riesgos (Res. SPDP-SPD-2026-0012-R) . . . 46
15.2 Guía de diseño y por defecto (Res. SPDP-SPD-2025-0040-R) . . . 46
15.3 Recursos pendientes . . . 46

Anexos . . . 47

Anexo A · Lista de verificación de la primera visita . . . 47
Anexo B · Guion de entrevista por área . . . 47
Anexo C · Puntos que el DPD debe verificar en el texto oficial . . . 47

CAPÍTULO 1

El kit en una página

Nueve herramientas numeradas en el orden de una intervención: se elige qué ofrecer, se cotiza, se mide, se inventaría, se califica la escala, se pondera el interés legítimo, se evalúa el riesgo, se adecúa la documentación y se prepara la respuesta. Al año, se vuelve a medir.

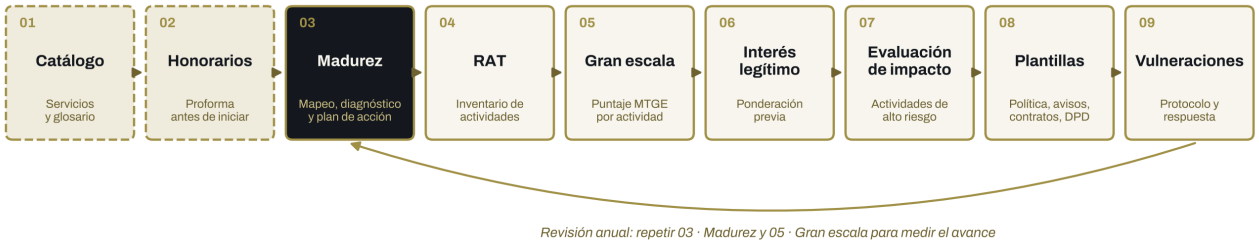


Figura 1. Orden de uso de las herramientas del kit. La numeración sigue este orden.

N.º	Herramienta	Cuándo se usa	Por qué es necesaria	Entregable
01	Catálogo de servicios y glosario	Antes de la primera propuesta	Saber qué ofrecer, a quién, con quién levantar información y cuánto cobrar; usar el vocabulario de la ley	Ficha de servicios y códigos para la proforma
02	Calculadora de honorarios	Después de la primera reunión, antes de empezar	Cobrar con método: ni por debajo del costo ni fuera de la capacidad del cliente	Proforma con IVA y firma
03	Nivel de madurez	Al inicio y cada año	Sin punto de partida medible no hay plan defendible ni evidencia de avance; estima la multa	Informe de diagnóstico y plan de acción
04	Registro de actividades (RAT)	Después del diagnóstico	Es el inventario obligatorio y la base de todos los demás documentos	RAT en Excel
05	Evaluación de gran escala	Sobre cada actividad del RAT	Toda organización debe evaluar si trata datos a gran escala; define si el DPD y la evaluación de impacto son obligatorios	Informe con el puntaje MTGE
06	Interés legítimo	Cuando el RAT usa el interés legítimo como base	La ponderación previa es obligatoria y su omisión es infracción grave	Informe de ponderación y fila del registro
07	Evaluación de impacto	Antes de tratamientos de alto riesgo o gran escala	Es obligatoria y previa en los casos del art. 42 LOPDP y de gran escala	Informe del art. 32 RGLOPDP
08	Kit de plantillas	Después del RAT	Cumple el deber de información, formaliza a los encargados y pone cláusulas en cada tipo de contrato	Políticas, avisos, contratos, cláusulas, DPD, derechos, seguridad, supervisión, diseño, capacitación
09	Kit de vulneraciones	Antes del incidente y en las primeras horas	Los plazos de notificación son de días	Protocolo, bitácora, notificaciones

1.1 Qué herramienta usar según el caso

No todos los clientes necesitan todo al mismo tiempo. Use esta tabla para decidir por dónde empezar.

Situación del cliente	Herramientas, en este orden	Por qué
Primer contacto con una empresa	01 › 02 › 03	Elegir servicios, cotizar y medir antes de prometer resultados
Nunca ha hecho nada en protección de datos	03 › 04 › 05 › 08 › 09	Construir la base documental en orden; sin RAT, la política queda vacía
Pregunta «¿estoy obligado a tener DPD?»	04 › 05	El puntaje oficial de gran escala responde con evidencia; revise además las causales de la Res. SPDP-SPD-2025-0028-R
Va a instalar reloj biométrico, cámaras, GPS o inteligencia artificial	05 › 07 › 08	Suele ser gran escala directa y requiere evaluación de impacto antes de empezar
Contratará un proveedor de nube, nómina o contabilidad	04 › 08	Actualizar el RAT y firmar el contrato de encargo
Envía publicidad a clientes, tiene cámaras de seguridad o controles antifraude sin consentimiento	04 › 06	Si la base es el interés legítimo, la ponderación previa es obligatoria
Necesita revisar sus contratos de trabajo, proveedores o aliados	04 › 08	La Res. SPDP-SPD-2025-0006-R exige cláusulas; elija la plantilla según el tipo de contrato
Ocurrió un incidente	09 de inmediato; luego 04 y 03	Los plazos corren desde que se tuvo constancia del incidente
Solo pide «una política de privacidad»	04 › 08	La política debe salir del RAT; explíquelo antes de cotizar
Un cliente corporativo o una licitación exige evidencia	03 › 04 › 05 › 08	El informe de madurez y el RAT son la evidencia más solicitada
Revisión anual	03 › 05 › 04	Medir avance, recalcular la escala y actualizar el inventario

BUENA PRÁCTICA

Use el asistente web en vivo durante las reuniones: el cliente ve cómo se construye el resultado y entiende el porqué de cada recomendación. Luego copie el resultado a Word o Excel y archívelo con la firma de responsabilidad.

CAPÍTULO 2

Marco de actuación del DPD en Ecuador

El DPD no es un redactor de políticas: es quien asesora, vela y supervisa de forma independiente que la organización cumpla, y quien deja evidencia de ello.

2.1 Las normas que usará todos los días

Norma	Qué regula	Herramienta
LOPDP (RO Supl. 459, 26-05-2021)	Principios, bases legitimadoras, derechos, transferencias, obligaciones, DPD, infracciones y sanciones	Todas
RGLOPDP (Decreto Ejecutivo 904, 2023)	Gran escala (art. 4 num. 7), RAT (arts. 38-44), evaluación de impacto (arts. 29-32), vulneraciones (arts. 24-28), encargo (arts. 40-43), DPD (arts. 48-55)	04, 05, 07, 08, 09
Res. SPDP-SPD-2026-0012-R	Guía de Gestión de Riesgos y Evaluación de Impacto, versión 2 (Cap. I obligatorio; Cap. II referencial): contexto, identificación, análisis, evaluación y tratamiento	03, 07
Res. SPDP-SPD-2025-0040-R	Guía de Protección de Datos desde el Diseño y por Defecto (art. 39 LOPDP; principios DevPrivOps)	01, 07
Res. SPDP-SPD-2025-0006-R	Obligación de incluir cláusulas de protección de datos en los contratos; defectos prohibidos y modelos referenciales por tipo de relación	08
Res. SPDP-SPD-2025-0022-R	Metodología de cálculo de multas (MPRIV-1 y MPUB-1)	03
Res. SPDP-SPD-2025-0028-R	Figura del DPD, causales de designación obligatoria y registro	05, 08
Res. SPDP-SPD-2025-0041-R	Interés legítimo: supuestos admisibles, prohibiciones y evaluación de ponderación previa	04, 06
Res. SPDP-SPD-2026-0004-R	Transferencias o comunicaciones nacionales e internacionales	04, 08
Res. SPDP-SPD-2026-0005-R	Tratamiento a gran escala: Modelo Técnico de Gran Escala (MTGE) y obligaciones reforzadas	02, 05
Res. SPDP-SPD-2026-0009-R y 0037-R	Protección de datos en sistemas de inteligencia artificial	07
Res. SPDP-SPD-2026-0039-R	Tratamiento de datos biométricos	05, 07
Res. SPDP-SPD-2026-0040-R	Notificación de vulneraciones de seguridad (SISPDP)	09
Ley Orgánica para el Fortalecimiento de la Ciberseguridad (mayo 2026)	Reforma del art. 43 LOPDP: notificación también al CSIRT	09

2.2 El principio que ordena todo: responsabilidad proactiva

QUÉ DICE LA NORMA

El responsable debe **acreditar** haber implementado mecanismos para la protección de datos personales (LOPDP art. 10 lit. k). No basta con cumplir: hay que poder demostrarlo.

Por eso cada herramienta del kit produce un **soporte documental**. Ante una inspección de la SPDP, la pregunta no será «¿cumple?», sino «¿cómo lo demuestra?». Note quién debe acreditar: **el responsable**, no el DPD (capítulo 3).

2.3 Vocabulario esencial para hablar con el cliente

Use siempre la terminología de la LOPDP; evite los términos del reglamento europeo (interesado, brecha, AEPD) salvo para comparar. El glosario completo, con las definiciones del art. 4 LOPDP y los conceptos del Reglamento y de la SPDP, está en la herramienta 01.

Término	Cómo explicarlo al cliente
Titular	La persona a quien pertenecen los datos: su cliente, su trabajador, su paciente
Responsable	Su empresa, cuando decide para qué y cómo usa los datos
Encargado	El proveedor que trabaja con sus datos para usted: contador, nómina, nube
Destinatario	Quien recibe datos para sus propios fines: SRI, IESS, aseguradora
Base legitimadora	La razón legal que le permite usar ese dato (art. 7 LOPDP)
Categorías especiales	Datos que, mal usados, pueden discriminar o dañar gravemente: salud, biométricos, NNA
Gran escala	Cuando su tratamiento es grande o delicado y la ley le exige más cuidado
Vulneración de la seguridad	Una fuga, pérdida o alteración de datos

CAPÍTULO 3

El rol del DPD: asesorar y supervisar, no implementar

Es el capítulo más importante para un DPD nuevo. Un cliente que cree que «contrató a alguien que hace la protección de datos» terminará decepcionado o, peor, convencido de que ya no es responsable de nada.

LA IDEA CENTRAL

El DPD no implementa. Asesora, vela y supervisa de forma independiente que el responsable cumpla (LOPDP arts. 4 y 49; RGLOPDP art. 48). Las decisiones, la aprobación de documentos y la ejecución de las medidas son del responsable: la empresa. La SPDP lo resume así: el DPD **no sustituye al responsable**, y la responsabilidad legal del cumplimiento permanece en él.

3.1 Funciones del DPD

Función (LOPDP art. 49)	En la práctica
Asesorar al responsable, a su personal y al encargado sobre la LOPDP, su reglamento y la normativa de la SPDP	Responder consultas, opinar sobre proyectos nuevos, revisar documentos antes de que la gerencia los apruebe
Supervisar el cumplimiento	Revisar el RAT, verificar evidencias, medir indicadores, informar desviaciones a la gerencia
Asesorar sobre análisis de riesgos, evaluaciones de impacto y medidas de seguridad, y supervisar su aplicación	Participar en la evaluación de impacto, opinar sobre las medidas y comprobar que se aplicaron
Cooperar con la SPDP y ser su punto de contacto	Recibir requerimientos, coordinar respuestas, acompañar en inspecciones
Otras que establezca la SPDP para categorías especiales	Seguir la normativa sectorial (biométricos, inteligencia artificial, gran escala)

3.2 Adecuación, implementación y supervisión

Son tres cosas distintas que el cliente suele confundir. Explíquelas en la primera reunión y déjelas escritas en la propuesta.

	Adecuación	Implementación	Supervisión
Qué es	Diagnosticar y documentar lo que la empresa debe cambiar para cumplir: RAT, políticas, avisos, contratos, procedimientos, plan de acción	Poner en operación las medidas: cambiar formularios, configurar sistemas, firmar contratos, publicar avisos, capacitar, ejecutar procedimientos	Verificar que lo documentado y lo implementado se cumple, medirlo e informar a la gerencia
Quién lo hace	La empresa, con asesoría. Un consultor externo puede redactar los borradores	La empresa: gerencia, dueños de procesos, TI y proveedores	El DPD
Quién decide y aprueba	La gerencia	La gerencia	El DPD informa; la gerencia decide
Entregable	Documentos aprobados y plan de acción	Medidas funcionando y evidencias	Informes, indicadores, recomendaciones
Herramientas del kit	03, 04, 05, 07, 08, 09	Ninguna: es trabajo de la empresa	03 (repetición), 05 (recálculo), 04 (revisión)

3.3 Quién hace qué

Actividad	Gerencia	Dueños de proceso	Sistemas (TI)	DPD
Decidir finalidades, bases y plazos	Decide	Propone	—	Asesora
Levantar la información de procesos	Facilita	Entrega	Entrega	Guía y revisa
Elaborar el RAT	Aprueba	Completa	Completa	Asesora y revisa
Aprobar política, avisos y procedimientos	Aprueba	Aplica	Aplica	Asesora
Firmar contratos de encargo	Firma	—	Identifica proveedores	Revisa el contenido
Medidas técnicas de seguridad	Financia	—	Implementa	Asesora y verifica
Evaluación de impacto	Aprueba	Describe el proceso	Describe sistemas	Asesora y supervisa
Atender solicitudes de derechos	Responde (firma)	Ejecuta	Ejecuta	Asesora y registra
Notificar una vulneración a la SPDP	Notifica	Informa	Contiene	Asesora y coordina
Capacitar al personal	Dispone	Asiste	Asiste	Puede impartir
Medir y reportar el cumplimiento	Recibe y decide	Aporta evidencia	Aporta evidencia	Ejecuta
Punto de contacto con la SPDP	—	—	—	Ejecuta

3.4 Responsabilidades y obligaciones del DPD

- **Cumplir sus funciones con diligencia.** Por su incumplimiento responde **administrativa, civil y penalmente** (LOPDP art. 49, inciso final). Por eso firme solo lo que verificó y deje constancia de cada recomendación.
- **Independencia.** Asesora, vela y supervisa de forma independiente; puede asumir otras tareas de protección de datos siempre que no generen conflicto, y el responsable debe darle recursos (RGLOPDP art. 48).
- **Confidencialidad** sobre la información que conozca, con acuerdo escrito.
- **Si es externo, es encargado** de los datos a los que accede: necesita contrato de encargo (RGLOPDP art. 41).
- **Registro** ante la SPDP cuando su designación es obligatoria, y requisitos de formación vigentes (Res. SPDP-SPD-2025-0028-R; RGLOPDP art. 55).
- **Documentar**: informes a la gerencia, actas, recomendaciones y su seguimiento. Es su propia evidencia.

3.5 Límites del DPD

El DPD no…	Por qué	Qué hacer en su lugar
Decide finalidades ni medios del tratamiento	Sería responsable, no supervisor, y perdería independencia	Recomendar por escrito; la gerencia decide
Sustituye al responsable ni asume su responsabilidad legal	La obligación de cumplir y acreditar es del responsable	Dejarlo claro en la propuesta y el contrato
Implementa controles técnicos ni administra sistemas	Supervisaría su propio trabajo	Asesorar a TI y verificar que lo hizo
Es oficial de cumplimiento, oficial de seguridad de la información ni apoderado especial	Incompatibilidad señalada por la SPDP (Oficio SPDP-IRD-2025-0197-O)	Declinar la acumulación de cargos

El DPD no…	Por qué	Qué hacer en su lugar
Aprueba sus propios documentos	Riesgo de autocontrol	Que los apruebe la gerencia y el DPD los revise
Garantiza que no habrá multas ni incidentes	El cumplimiento depende de lo que la empresa ejecute	Ofrecer reducción de riesgo y evidencia, no garantías

3.6 Si usted adecúa y luego será el DPD

Es el modelo de negocio más común: el consultor hace la adecuación y después ofrece el servicio de DPD externo. Es posible, pero cuide la independencia:

1. Contrate por separado la adecuación (asesoría) y la función de DPD (supervisión), con alcances distintos.
2. Los documentos que usted redacte son **borradores**: la gerencia los revisa, los aprueba y los firma como propios.
3. La implementación la ejecuta la empresa; usted la verifica después, como DPD, con evidencia.
4. Si detecta que debe supervisar algo que usted mismo diseñó, dígalo en el informe y proponga una revisión independiente cuando el riesgo sea alto.

CÓMO DECIRLO AL CLIENTE

«Yo no voy a instalar el antivirus ni a firmar sus contratos: eso lo hacen ustedes, porque la ley pone la responsabilidad en la empresa. Mi trabajo es decirles qué hacer, revisar que lo hagan bien y responder ante la Superintendencia como su punto de contacto. Así, cuando los visiten, tendrán evidencia de que cumplen y un especialista independiente que lo respalda.»

ERROR FRECUENTE

Aceptar «hágalo todo usted». El DPD termina implementando, supervisándose a sí mismo y respondiendo por decisiones que no tomó. Proponga la adecuación como asesoría con entregables y deje la ejecución en manos de la empresa.

3.7 Roadmap de la gestión del DPD en la empresa

El roadmap resume la intervención completa en dos carriles: arriba, lo que hace el DPD o consultor; abajo, lo que hace la empresa. Úselo en la primera reunión para que la gerencia entienda desde el inicio quién decide y quién implementa.

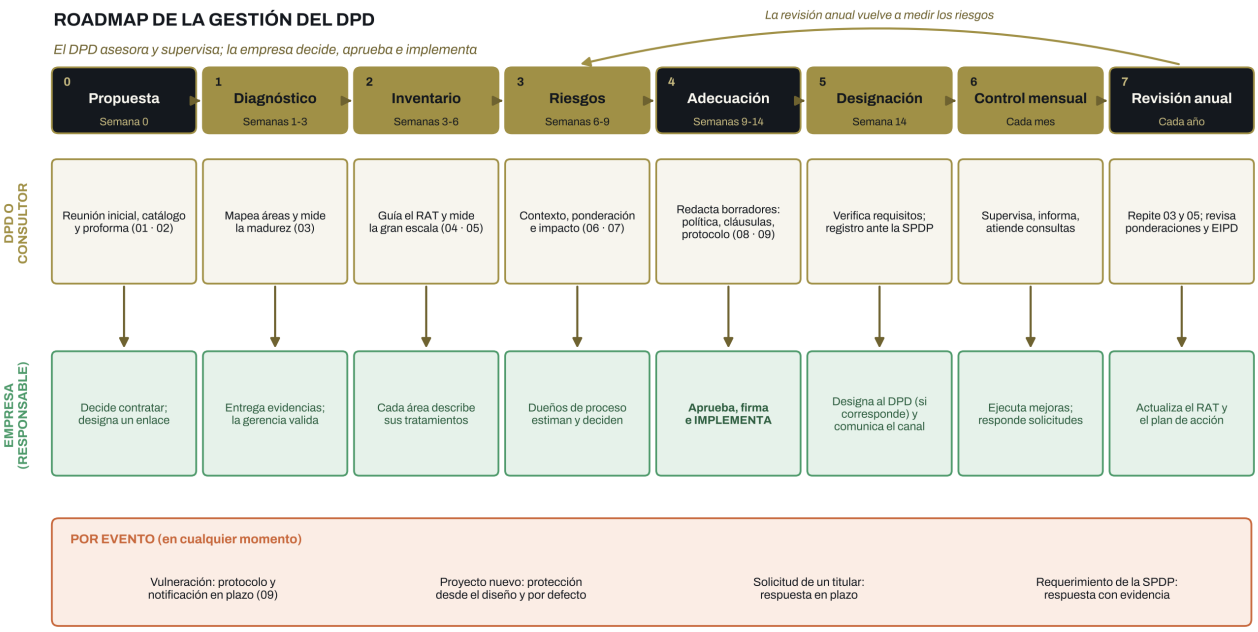


Figura 2. Roadmap de la gestión del DPD: ocho etapas, dos carriles y los eventos que pueden ocurrir en cualquier momento. Las semanas son criterio propio para una pyme.

CÓMO DECIRLO AL CLIENTE

«Este es el camino. En cada etapa yo le preparo el análisis o el borrador, y su equipo decide y lo pone en práctica. Al final del primer año volvemos a medir, para demostrar el avance ante la Superintendencia.»

CAPÍTULO 4

Metodología de intervención

Una intervención ordenada evita el error más común: redactar políticas antes de saber qué datos trata la empresa.

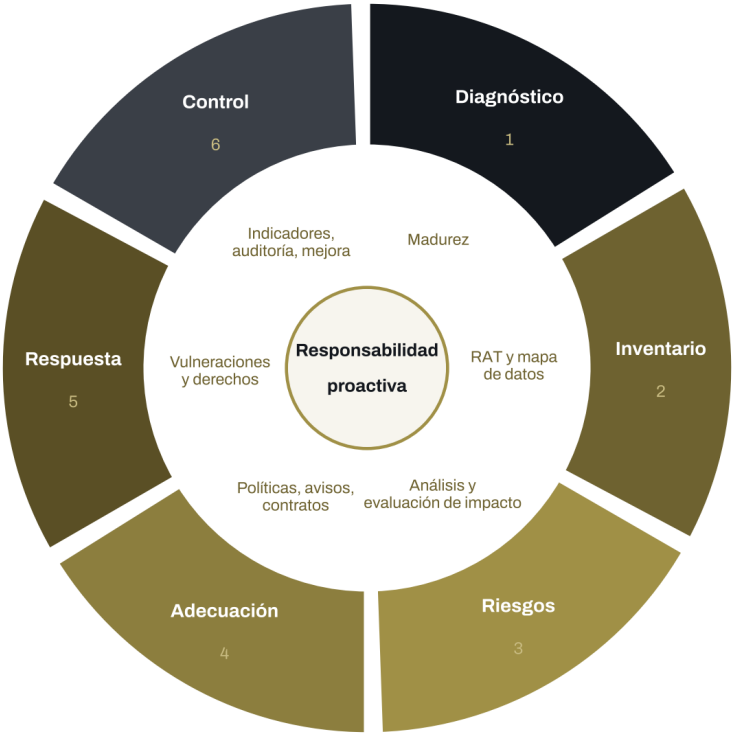


Figura 3. Ciclo de intervención del DPD. Cada fase alimenta a la siguiente; el control reinicia el ciclo.

Fase	Objetivo	Herramienta	Quién ejecuta	Entregable	Duración*
0. Propuesta	Elegir servicios y cotizar	01 · 02	Consultor	Ficha de servicios y proforma	1 a 3 días
1. Diagnóstico	Mapear la empresa y medir su punto de partida	03 · cap. 6	Consultor con la empresa	Informe de diagnóstico	1 a 2 semanas
2. Inventario	Saber qué datos se tratan, dónde, para qué, con quién y a qué escala	04 · 05 · cap. 7 y 8	Empresa, guiada por el consultor	RAT, mapa de flujos, informe de gran escala	2 a 6 semanas
3. Riesgos	Ponderar el interés legítimo, valorar riesgos y decidir medidas	06 · 07	Empresa, con asesoría del DPD	Ponderaciones y evaluaciones de impacto	1 a 3 semanas por tratamiento
4. Adecuación e implementación	Documentar y poner en marcha las medidas	08 · 09	Empresa (aprueba y ejecuta); consultor redacta borradores	Documentos aprobados y medidas funcionando	2 a 8 semanas
5. Control	Supervisar y medir	03 · 05 (repetición) · cap. 12	DPD	Reportes e informe anual	Permanente

* Criterio propio para una pyme de 20 a 100 trabajadores. Depende del tamaño, el sector y la colaboración del cliente.

ERROR FRECUENTE

Empezar por la política de privacidad. Sin RAT no se sabe qué finalidades, bases ni plazos declarar: la política queda genérica y no protege a nadie.

CAPÍTULO 5

Abordaje al cliente y propuestas

El cliente no compra cumplimiento normativo: compra tranquilidad, reducción de riesgo y una respuesta clara ante la autoridad. El DPD debe traducir la norma a esos términos.

5.1 Antes de la primera reunión

- Identifique el **sector** y si trata categorías especiales (salud, educación, seguridad privada, financiero, biométricos).
- Estime el **tamaño**: con 100 o más trabajadores el RAT es obligatorio sin más análisis (art. 38 RGLOPDP).
- Revise su **sitio web**: formularios, política publicada, cookies, chat de WhatsApp.
- Verifique si la actividad está entre las causales de **designación obligatoria de DPD** (Res. SPDP-SPD-2025-0028-R) o si probablemente es de **gran escala** (capítulo 9.5).
- Prepare la ficha de mapeo del capítulo 6 y lleve abiertos los asistentes 02 y 03.

5.2 Guion de la primera reunión (30 minutos)

1. **Apertura (3 min)**
   Presente el objetivo: entender cómo la empresa trata datos personales y mostrar su nivel de exposición. Aclare que no es una auditoría punitiva.
2. **Contexto del negocio (7 min)**
   Pregunte por procesos, no por datos: «¿Cómo llega un cliente nuevo? ¿Qué pasa cuando contratan a alguien? ¿Qué proveedores usan para facturar, nómina o correo?».
3. **Cinco preguntas clave (10 min)**
   ¿Tienen un listado de las bases de datos? ¿Quién decide cuánto tiempo se guardan? ¿Los proveedores firmaron cláusulas de protección de datos? ¿Qué harían mañana si les roban la laptop de contabilidad? ¿Alguien ha pedido que borren sus datos?
4. **Hallazgo inmediato (5 min)**
   Comparta un hallazgo concreto y verificable (por ejemplo, el formulario web sin aviso de privacidad).
5. **Rol y cierre (5 min)**
   Explique en una frase qué hace y qué no hace el DPD (capítulo 3) y proponga el diagnóstico de madurez como primer paso acotado, con fecha y precio cerrado.

> **CÓMO DECIRLO AL CLIENTE**
> *«Su empresa trata datos personales todos los días: al facturar, al pagar la nómina, al grabar con sus cámaras. La ley no le prohíbe hacerlo; le exige poder demostrar que lo hace bien. En dos semanas le entrego un diagnóstico con su nivel de cumplimiento, cuánto podría costarle una sanción y qué hacer primero.»*

5.3 Objeciones frecuentes

El cliente dice…	Respuesta técnica y clara
«Somos pequeños, eso no nos aplica»	La LOPDP aplica a todo responsable. Con menos de 100 trabajadores, el RAT es obligatorio si el tratamiento no es ocasional, implica riesgo o incluye categorías especiales (art. 39 RGLOPDP). Y toda organización debe evaluar si alguno de sus tratamientos es de gran escala.

El cliente dice…	Respuesta técnica y clara
«Nadie ha sido sancionado todavía»	La SPDP ya publicó su metodología de cálculo de multas y la notificación de vulneraciones es obligatoria. El diagnóstico muestra su exposición en dólares, sobre su propio volumen de negocio.
«Ya tenemos una política en la web»	La política es la última pieza, no la primera. Debe reflejar finalidades, bases y plazos reales, que salen del RAT.
«Eso lo ve el área de sistemas»	Sistemas protege la información; la protección de datos decide qué datos se pueden tratar, para qué y por cuánto tiempo. Son complementarios.
«Si lo contrato a usted, ya cumplo»	No: el responsable sigue siendo la empresa. Yo asesoro y superviso; ustedes deciden y ejecutan. Por eso la propuesta separa lo que yo entrego de lo que ustedes implementan.
«Es muy caro»	Compare el plan con la multa estimada y el riesgo anual esperado del diagnóstico; la herramienta 03 lo calcula con sus números.

5.4 Cómo presentar la propuesta de evaluación

Sección	Contenido
1. Antecedentes	Lo que entendió del negocio en la reunión, en dos párrafos.
2. Objetivo	Determinar el nivel de madurez, la exposición económica estimada y las acciones prioritarias.
3. Alcance	Entidad, sedes y procesos incluidos. Indique lo excluido (por ejemplo, pruebas técnicas de seguridad).
4. Metodología	Mapeo de la empresa, entrevistas por área, revisión documental, herramienta de madurez (12 dominios) y estimación de multa con la metodología de la SPDP.
5. Entregables	Informe de diagnóstico con índice, radar, multa estimada, apetito al riesgo y plan de acción; presentación a la gerencia.
6. Rol del consultor y de la empresa	Qué hace el consultor (diagnóstico y recomendaciones) y qué hace la empresa (entregar información, decidir, ejecutar).
7. Información requerida	Organigrama, proveedores con acceso a datos, formularios y contratos tipo, ingresos del ejercicio anterior, contacto por área.
8. Cronograma	Por semana: inicio, entrevistas, análisis, entrega y presentación.
9. Confidencialidad	Acuerdo de confidencialidad y, si accederá a datos personales, contrato de encargo (art. 41 RGLOPDP).
10. Servicios y honorarios	Servicios con sus códigos del catálogo (herramienta 01) y valores de la proforma (herramienta 02), sin IVA y con IVA; forma de pago y vigencia.

5.5 Cómo presentar la propuesta de control

Modalidad	Cuándo conviene	Incluye
DPD externo designado	La organización está obligada a designar DPD (gran escala o Res. 0028) y no tiene perfil interno	Funciones del art. 49 LOPDP, registro ante la SPDP, supervisión, reportes
Acompañamiento de cumplimiento	Tiene responsable interno pero necesita soporte experto	Revisión trimestral del RAT, asesoría en proyectos nuevos, capacitación
Revisión anual	Organización pequeña con riesgo bajo	Repetición de las herramientas 03 y 05 y actualización documental

La propuesta de control debe fijar **indicadores** (capítulo 12), la **frecuencia de reportes**, los **tiempos de respuesta** ante una vulneración (el encargado comunica al responsable en máximo 2 días y el responsable notifica a la SPDP en el término de 5 días) y lo que **no** incluye: implementar medidas técnicas o decidir por la

empresa.

CÓMO DECIRLO AL CLIENTE

«La adecuación deja la casa en orden; el control evita que se desordene. Cada trimestre le entrego un tablero con cinco indicadores y, si ocurre un incidente, ya sabemos quién hace qué y en qué plazo.»

5.6 Cómo fijar los honorarios

En Ecuador no existe una tabla oficial ni gremial de honorarios del DPD. La herramienta 02 propone tres miradas del mismo servicio y una regla de decisión. Tramos y tarifas son **criterio propio**, ajustables a su mercado.

Método	Pregunta que responde	Úselo para
Volumen de negocio	¿Cuánto puede pagar este cliente?	Anclar el precio a su tamaño (las ventas prevalecen sobre los trabajadores)
Volumen de tratamiento	¿Cuánto exige su tratamiento de datos?	Justificar el precio con el puntaje oficial MTGE de la SPDP
Estimación técnica	¿Cuánto cuesta mi tiempo?	Fijar el piso: nunca cotizar por debajo

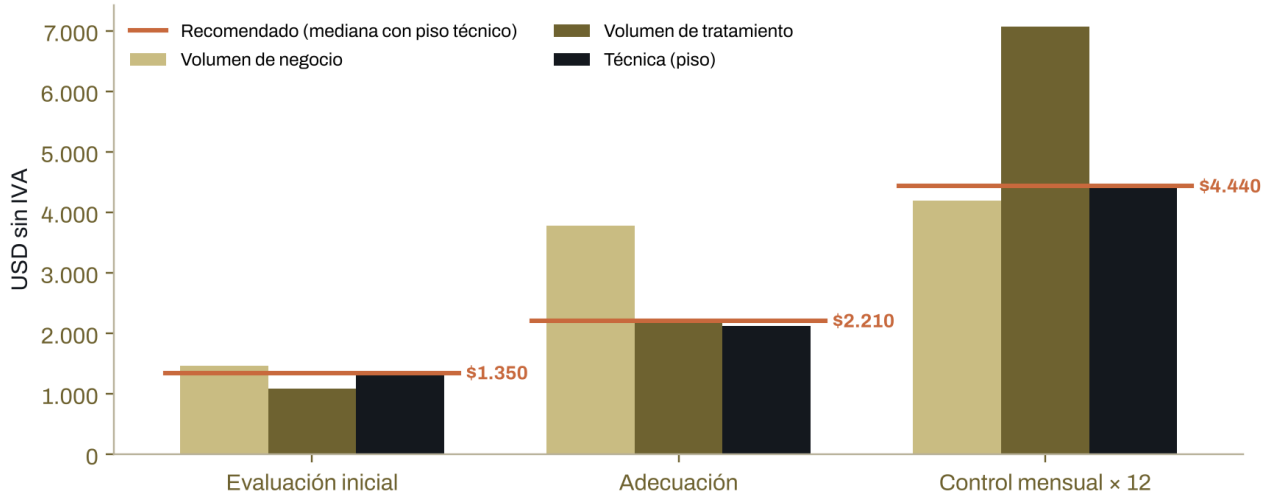


Figura 4. Honorarios del ejemplo ficticio por método (sin IVA). La recomendación es la mediana, nunca inferior al costo técnico.

BUENA PRÁCTICA

Si el cliente pide rebaja, reduzca el alcance antes que el precio. Presente los valores sin IVA y el total con IVA (15 %), separando el pago único del mensual.

5.7 Kit comercial: carta de presentación y campaña de correos

La herramienta 01 incluye dos documentos para buscar clientes: una **carta de presentación** genérica, adaptable a cualquier empresa, y una **secuencia de cinco correos** con dos respuestas tipo.

Correo	Día	Propósito
1 · Presentación	1	Plantear la obligación y ofrecer una reunión de 30 minutos
2 · Educativo	4	Cinco preguntas que la SPDP puede hacer; generar autodiagnóstico
3 · Riesgo	9	Contrato de encargo y cláusulas: una infracción grave fácil de corregir
4 · Propuesta	15	Alcance, plazo y honorarios del diagnóstico

Correo	Día	Propósito
5 · Cierre cordial	22	Cerrar sin presión y dejar la puerta abierta

ATENCIÓN

Practique lo que ofrece. El correo de un contacto empresarial es un dato personal: envíe solo con una base de legitimación, sin bases compradas, con una forma gratuita e inmediata de darse de baja en cada mensaje. Si la base es el interés legítimo para mercadotecnia directa, haga primero la ponderación con la herramienta 06. No invente urgencias ni cifras.

CAPÍTULO 6

Mapeo inicial de la empresa

Antes de aplicar el diagnóstico de madurez, el DPD debe conocer la empresa: cómo está organizada, qué procesos tiene, qué sistemas usa y quién puede responder cada pregunta. El mapeo convierte un cuestionario genérico en un diagnóstico con evidencia.

6.1 Qué buscar antes de la primera entrevista

Fuente	Qué revela	Dominio de madurez
Sitio web y formularios	Política publicada, avisos, cookies, canales de recolección	Transparencia, Licitud
Redes sociales y anuncios	Campañas, concursos, captación de contactos, uso de imágenes	Licitud, Transparencia
Información societaria y estados financieros públicos (si es compañía)	Tamaño, ventas del ejercicio anterior, grupo empresarial	Base para las herramientas 02 y 03
Visita a las instalaciones	Cámaras y letreros, relojes biométricos, archivos abiertos, pantallas visibles	Seguridad, Transparencia
Ofertas de empleo publicadas	Datos que piden a postulantes, uso de plataformas externas	Licitud, Encargados

6.2 Ficha de perfil de la empresa

Dato	Para qué sirve	Quién lo entrega
Sector, actividad, tamaño, ventas y trabajadores	Clasificar la empresa, cotizar y estimar la multa	Gerencia, contabilidad
Organigrama y responsables por área	Planificar entrevistas y asignar dueños de proceso	Gerencia, talento humano
Sedes, sucursales y cobertura	Alcance geográfico (gran escala) y visitas	Gerencia
Procesos principales	Base de las actividades del RAT (capítulo 10)	Dueños de proceso
Sistemas y soportes (ERP, nómina, CRM, nube, Excel, papel)	Inventario y seguridad	Sistemas
Proveedores con acceso a datos	Encargados y contratos	Compras, contabilidad
Indicadores de categorías especiales (salud, biométricos, NNA, cámaras)	Gran escala directa y evaluación de impacto	Talento humano, seguridad
Incidentes y reclamos previos	Vulneraciones y derechos	Gerencia, servicio al cliente
Documentos existentes (política, contratos, procedimientos)	Punto de partida de la adecuación	Legal, gerencia

6.3 Matriz de áreas y dominios

Cada área de la empresa responde mejor ciertos dominios de la herramienta 03. Use la matriz para decidir a quién entrevistar y qué evidencia pedirle; así evita preguntar todo a la gerencia, que suele no conocer el detalle operativo.

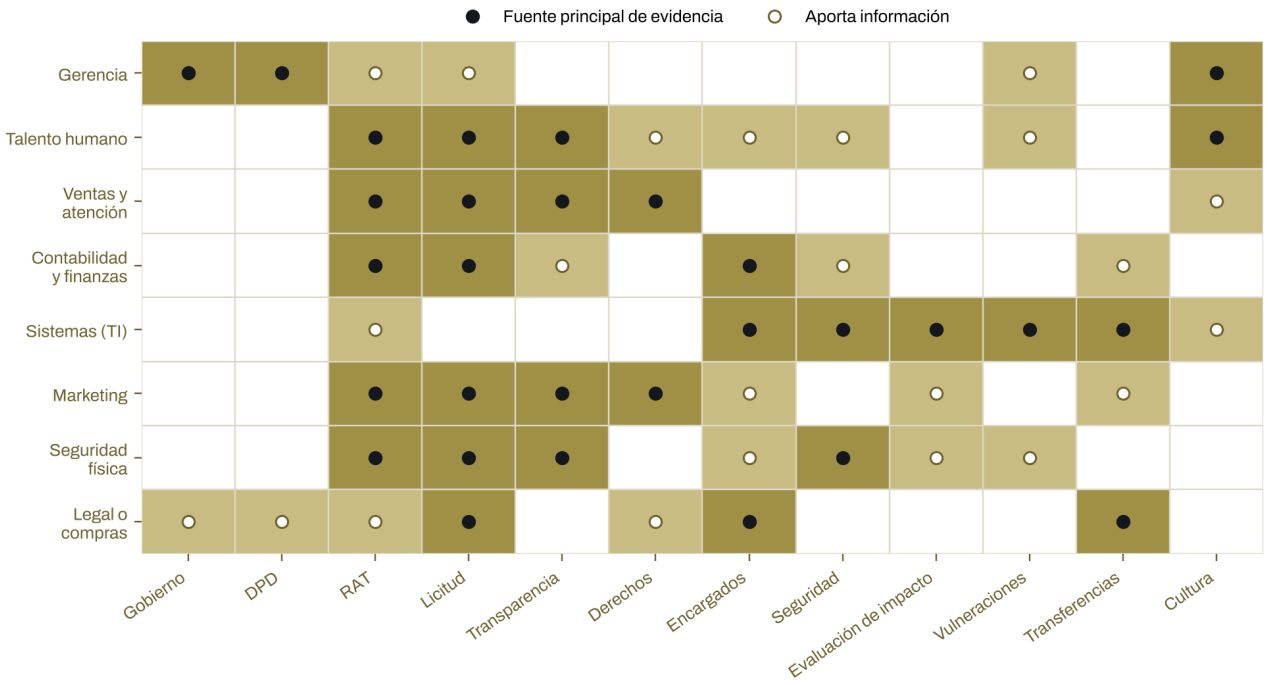


Figura 5. Matriz de mapeo: qué área aporta evidencia para cada dominio del diagnóstico de madurez (criterio propio).

6.4 Señales observables

Señal	Qué suele indicar	Dominio
No hay aviso en el formulario web	No se cumple el deber de información	Transparencia
Cámaras sin letrero	Videovigilancia sin aviso; posible gran escala si captan la vía pública	Transparencia, Seguridad
Reloj biométrico de asistencia	Gran escala directa; evaluación de impacto pendiente	Evaluación de impacto
Hojas de vida en el correo del gerente	Sin plazo de conservación ni control de acceso	RAT, Seguridad
Contador o nómina externos sin contrato de protección de datos	Encargados sin contrato: infracción grave	Encargados
Nadie sabe a quién avisar si se pierde una laptop	No hay protocolo de vulneraciones	Vulneraciones
Datos de clientes en grupos de WhatsApp personales	Tratamiento sin control ni registro	RAT, Seguridad, Cultura

6.5 Del mapeo al diagnóstico

1. **Complete la ficha de perfil**
   Con la información pública y la que entregue la gerencia. Registre los datos en la pestaña de contexto de la herramienta 03.
2. **Arme la agenda de entrevistas**
   Con la matriz de áreas y dominios: una entrevista de 45 minutos por área, con el guion del Anexo B.
3. **Formule hipótesis**
   Marque en el cuestionario los puntajes que espera según las señales observadas. Le ayudarán a enfocar las preguntas.

4 **Valide con evidencia**

En cada entrevista pida el documento o la pantalla que respalda la respuesta. Sin evidencia, el puntaje no supera 2.

5 **Aplique la herramienta 03**

Complete el cuestionario, revise el radar y el plan de acción, y cruce el resultado con las señales del mapeo.

CAPÍTULO 7

Cómo identificar los datos que trata una empresa

Existen estructuras reconocidas para hacerlo. La legal es el RAT; la técnica más difundida es el inventario y mapeo de datos del NIST Privacy Framework; la de escala es el MTGE de la SPDP. El kit combina las tres.

7.1 Las estructuras de referencia

Estructura	Qué aporta	Cómo se usa en el kit
RAT (art. 38 RGLOPDP)	El contenido mínimo legal del inventario	Herramienta 04
Registro Nacional de Protección de Datos (art. 51 LOPDP)	Inscripción de las bases de datos ante la autoridad	Dominio RAT de la herramienta 03
NIST Privacy Framework, categoría ID.IM-P	Ocho preguntas para levantar el inventario de forma sistemática	Método del apartado 7.3
Modelo Técnico de Gran Escala (Res. SPDP-SPD-2026-0005-R)	Seis variables por tratamiento con umbral oficial; el cálculo debe constar en el RAT	Herramienta 05
ISO/IEC 27701 e ISO/IEC 29100	Roles, ciclo de vida del dato y registros dentro de un sistema de gestión	Capítulo 13

7.2 Las ocho preguntas del inventario (NIST ID.IM-P)

Subcategoría	Pregunta práctica	Columna del RAT
ID.IM-P1 Sistemas	¿Qué sistemas, aplicaciones y archivos físicos contienen datos personales?	Sistemas y soportes
ID.IM-P2 Propietarios y roles	¿Quién es dueño de cada sistema y qué rol tiene (responsable, encargado)?	Responsable interno · encargados
ID.IM-P3 Titulares	¿De quiénes son los datos?	Categorías de titulares
ID.IM-P4 Acciones	¿Qué se hace con ellos: recoger, consultar, comunicar, borrar?	Ciclo de vida · perfiles
ID.IM-P5 Finalidades	¿Para qué se usan?	Finalidades
ID.IM-P6 Elementos de datos	¿Qué datos exactamente?	Categorías de datos
ID.IM-P7 Entorno	¿Dónde se tratan: local, nube, terceros, otro país?	Encargados · transferencias
ID.IM-P8 Mapa	¿Cómo fluyen los datos de punta a punta?	Mapa de flujos (capítulo 8)

7.3 Método de levantamiento en seis pasos

1 **Mapa de procesos**

Parta de la ficha de perfil (capítulo 6) y liste los macroprocesos (capítulo 10).

2 **Entrevistas por área**

Con el guion del Anexo B. Pregunte por procesos y formularios, no por «bases de datos».

3 **Inventario de sistemas y soportes**
ERP, nómina, CRM, correo, hojas de cálculo, WhatsApp corporativo, cámaras y archivo físico.

4 **Ciclo de vida por actividad**
Las seis etapas del capítulo 8: captación, registro, uso, comunicación, conservación y supresión.

5 **Mapa de flujos**
Origen, recolección, sistemas, encargados y destinatarios. Distinga encargo de comunicación.

6 **Validación y registro**
Valide con el dueño de cada proceso, cargue el RAT (herramienta 04) y puntúe cada actividad con la herramienta 05.



Figura 6. Mapa de flujos de una pyme ficticia. El proveedor de nube en EE. UU. es un encargado: su ubicación en el exterior no convierte el encargo en transferencia internacional.

ERROR FRECUENTE

Preguntar «¿qué bases de datos tienen?». La respuesta casi siempre es «solo la de clientes». Pregunte por procesos: así aparecen la nómina, las cámaras, el grupo de WhatsApp de ventas y las hojas de vida en el correo del gerente.

CAPÍTULO 8

El recorrido de los datos: encargo y transferencia

La forma más clara de explicar la protección de datos a un gerente es seguir un dato desde que entra a la empresa hasta que se borra. En cada etapa aparece una obligación concreta.

8.1 Las seis etapas

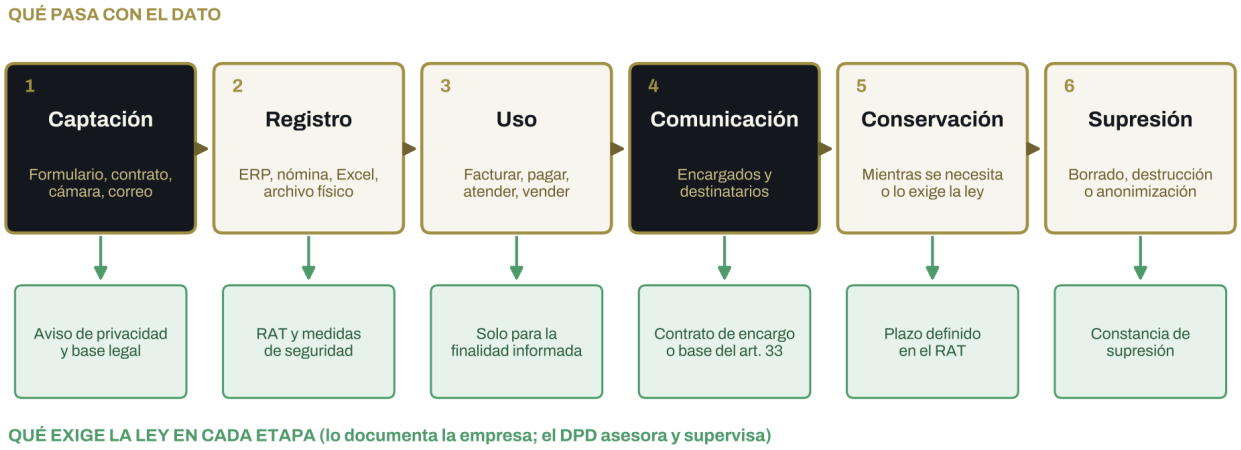


Figura 7. Recorrido del dato y lo que la ley exige en cada etapa.

Etapa	Pregunta del DPD	Documento o medida	Herramienta
1. Captación	¿Se informó a la persona y hay base legal?	Aviso de privacidad; consentimiento solo cuando es la base	04, 08
2. Registro	¿Dónde queda y quién accede?	RAT; controles de acceso	04
3. Uso	¿Se usa solo para lo informado?	Finalidades del RAT; evaluación de impacto si el riesgo es alto	04, 05, 07
4. Comunicación	¿Sale a un encargado o a un destinatario?	Contrato de encargo o base del art. 33 LOPDP	04, 08
5. Conservación	¿Cuánto tiempo y por qué?	Plazo en el RAT y en la política	04, 08
6. Supresión	¿Cómo y cuándo se elimina?	Procedimiento y constancia de supresión	08

8.2 Encargo frente a comunicación o transferencia

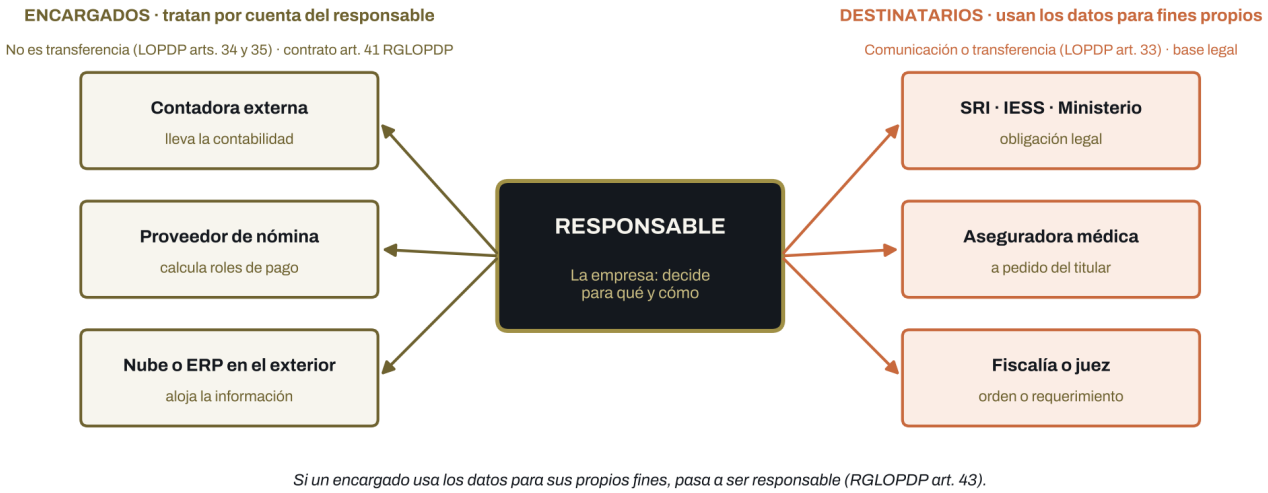


Figura 8. Encargados (trabajan para la empresa) y destinatarios (usan los datos para sus fines).

	Encargo	Comunicación o transferencia
Quién recibe	Un proveedor que presta un servicio al responsable	Un tercero que usará los datos para sus propios fines
Para qué usa los datos	Solo según las instrucciones del responsable	Para sus finalidades; pasa a ser responsable
Qué exige la ley	Contrato de encargo con el contenido del art. 41 RGLOPDP (LOPDP arts. 34 y 35)	Base de legitimación y, cuando corresponda, consentimiento informado (LOPDP art. 33)
Si está en el exterior	Sigue siendo encargo: no se vuelve transferencia internacional por la ubicación (Oficio SPDP-IRD-2026-0300-O)	Transferencia internacional: régimen del art. 56 LOPDP y Res. SPDP-SPD-2026-0004-R
Ejemplos	Contador externo, proveedor de nómina, nube, empresa de seguridad que monitorea cámaras	SRI, IESS, Ministerio del Trabajo, aseguradora, Fiscalía, otra empresa del grupo que usa los datos para lo suyo
Señal de alerta	El proveedor usa los datos para sus propios fines: pasa a ser responsable (RGLOPDP art. 43)	Se envían datos sin base legal o sin informar al titular

CONCEPTO CLAVE

Pregunta clave para distinguirlos: **¿para quién trabaja quien recibe los datos?** Si trabaja para su empresa, es encargo. Si los usa para sí mismo, es comunicación o transferencia.

8.3 Caso 1 · María compra en la ferretería

María compra materiales en la Ferretería Ficticia El Tornillo y pide factura con sus datos.

Etapa	Qué pasa	Rol de quien recibe	Qué necesita la empresa
Captación	Da su nombre, cédula, correo y dirección para la factura	—	Aviso de privacidad en caja; base: obligación legal tributaria
Registro	Sus datos se guardan en el ERP, alojado en un proveedor de nube en EE. UU.	Proveedor de nube: encargado en el exterior	Contrato de encargo; el RAT indica la ubicación
Comunicación	La factura electrónica llega al SRI	SRI: destinatario por obligación legal	Base legal en el RAT; no requiere consentimiento
Comunicación	La contadora externa revisa las ventas	Contadora: encargada	Contrato de encargo firmado

Etapa	Qué pasa	Rol de quien recibe	Qué necesita la empresa
Nuevo uso	Ventas quiere enviarle promociones	—	Nueva finalidad: consentimiento u otra base válida, e informarle
Conservación	La factura se archiva el plazo que exige la normativa tributaria	—	Plazo en el RAT; acceso restringido
Supresión	María pide que no le envíen más publicidad	—	Atender la solicitud en plazo y registrarla

CÓMO EXPLICÁRSELO AL GERENTE

«Cuando María le da su cédula para la factura, usted la puede usar porque la ley tributaria lo exige. El SRI la recibe por ley. Su contadora y su sistema en la nube trabajan para usted, así que necesita un contrato con cada uno. Pero si quiere mandarle promociones, eso es otra finalidad: necesita su autorización.»

8.4 Caso 2 · Juan es contratado

Juan se postula a un cargo de bodeguero, es contratado y empieza a marcar asistencia con huella.

Etapa	Qué pasa	Rol de quien recibe	Qué necesita la empresa
Captación	Envía su hoja de vida; luego entrega cédula, cuenta bancaria, certificado médico y datos de sus hijos (cargas)	—	Aviso a postulantes y trabajadores; datos de salud y de NNA son categorías especiales
Registro	Se crea su ficha en el sistema de nómina de un proveedor	Proveedor de nómina: encargado	Contrato de encargo
Uso	Marca asistencia con huella dactilar	—	Biométrico: gran escala directa (herramienta 05) y evaluación de impacto previa (herramienta 07)
Comunicación	Se le afilia al IESS y se registra el contrato ante el Ministerio del Trabajo	IESS y Ministerio: destinatarios por obligación legal	Base legal en el RAT
Comunicación	La empresa lo incluye en el seguro médico privado de grupo	Aseguradora: destinataria que usa los datos para sus fines	Base de legitimación e información al trabajador; analizar el caso
Conservación y supresión	Al terminar la relación, se conservan solo los datos exigidos por ley; las hojas de vida no seleccionadas se eliminan	—	Plazos en el RAT; constancia de supresión

CÓMO EXPLICÁRSELO AL GERENTE

«La ley le obliga a dar los datos de Juan al IESS: ahí no necesita su permiso. El proveedor de nómina trabaja para usted: firme un contrato con él. La huella es un dato biométrico: antes de usar el reloj, la ley le pide evaluar los riesgos y probablemente tener un delegado. Y la hoja de vida de quien no contrató no se guarda indefinidamente.»

8.5 Caso 3 · Un visitante y las cámaras

Un cliente entra al local; las cámaras lo graban. Días después, la Fiscalía solicita las grabaciones por un robo en la calle.

Etapa	Qué pasa	Rol de quien recibe	Qué necesita la empresa
Captación	La cámara capta su imagen al ingresar	—	Letrero de videovigilancia con la información básica
Registro	Una empresa de seguridad monitorea y almacena las grabaciones	Empresa de seguridad: encargada	Contrato de encargo
Uso	Si las cámaras captan la vía pública de forma sistemática	—	Gran escala directa (Res. SPDP-SPD-2026-0005-R art. 14.3) y evaluación de impacto
Comunicación	La Fiscalía solicita las grabaciones	Fiscalía: destinataria por orden o requerimiento	Verificar el requerimiento formal y registrar la entrega
Conservación y supresión	Las grabaciones se sobrescriben tras un plazo corto	—	Plazo definido en el RAT

CÓMO EXPLICÁRSELO AL GERENTE

«Grabar su local es legítimo para su seguridad, pero debe avisarlo con un letrero. La empresa de seguridad trabaja para usted: firme un contrato. Si sus cámaras graban la calle, la ley lo considera tratamiento a gran escala. Y si la Fiscalía pide las grabaciones con un requerimiento formal, puede entregarlas: deje constancia.»

BUENA PRÁCTICA

Otro ejemplo frecuente: dentro de un grupo empresarial, si la casa matriz presta el servicio de sistemas a la filial, es encargo; si recibe los datos de clientes para venderles sus propios productos, es transferencia y necesita base legal (LOPDP art. 33).

CAPÍTULO 9

Las herramientas paso a paso

Cada herramienta se presenta en el orden de uso con la misma estructura: qué es, por qué es necesaria, cuándo usarla según el caso, cómo, un ejemplo, los errores frecuentes y cómo explicarla.

9.1 Herramienta 01 · Catálogo de servicios y glosario

Qué es	Catálogo de 28 servicios (S01 a S28) por fase, con qué es, cómo se aplica, para quién, qué se obtiene, departamento responsable, con quién levantar información, recomendaciones y precio sugerido por tamaño. Incluye el glosario del art. 4 LOPDP, del Reglamento y de la SPDP, y el kit comercial: carta de presentación y campaña de correos (capítulo 5.7).
Por qué	Un DPD nuevo suele ofrecer «protección de datos» en abstracto. El catálogo le permite ofrecer servicios concretos, con alcance claro y el mismo nombre y código en la proforma, el contrato y la factura.
Según el caso	Antes de cada propuesta. Con clientes recurrentes, para ofrecer servicios de control anual o por evento. El glosario, siempre que redacte para un cliente o explique un término.
Entregable	Códigos para la proforma; catálogo para el cliente y ficha interna en Word; glosario en Word.

1. **Ubique la fase del cliente**
   Evaluación inicial, inventario y riesgos, adecuación, control o por evento.
2. **Revise la naturaleza del servicio**
   Asesoría, borradores para aprobación, supervisión, formación o acompañamiento ante la autoridad: deja claro qué hace usted y qué hace la empresa.
3. **Prepare el levantamiento**
   Cada servicio indica el departamento responsable y con quién conversar.
4. **Copie los códigos**
   Péguelos en la proforma de la herramienta 02 con «Importar del catálogo».
5. **Entregue el catálogo al cliente**
   La versión para el cliente omite las recomendaciones internas.

Fase	Servicios
Evaluación inicial	S01 reunión inicial · S02 diagnóstico de madurez · S03 gran escala y DPD · S04 informe a la gerencia
Inventario y riesgos	S05 RAT · S06 evaluación de impacto · S07 ponderación del interés legítimo · S08 encargos y transferencias
Adecuación	S09 programa integral · S10 política y avisos · S11 contratos y cláusulas por tipo de contrato · S12 política interna y roles · S13 conservación y supresión · S14 derechos · S15 protocolo de vulneraciones · S16 sitio web · S17 capacitación
Control mensual y anual	S18 DPD externo · S19 acompañamiento · S20 informe anual · S21 auditoría independiente
Por evento	S22 vulneración · S23 solicitud de derechos · S24 privacidad desde el diseño · S25 evaluación de proveedor · S26 simulacro · S27 requerimientos y consultas a la SPDP · S28 hora adicional

ATENCIÓN

No audite (S21) a un cliente del que es DPD o al que adecuó: perdería independencia. Si además patrocinará a la empresa en un procedimiento sancionador (S27), evalúe el conflicto con su función de punto de contacto ante la SPDP.

9.2 Herramienta 02 · Calculadora de honorarios

Qué es	Calculadora con seis pestañas: cliente, volumen de negocio, volumen de tratamiento (MTGE), estimación técnica, comparar y decidir, y proforma con valores sugeridos, IVA y firma.
Por qué	Cotizar sin método lleva a cobrar de menos a las pymes con muchos datos o de más a las que no pueden pagar. Da un rango defendible y argumentos de valor honestos.
Según el caso	Indispensable en toda oferta. En clientes recurrentes, actualice la proforma cada año. Si el cliente solo pide una consulta puntual, use la tarifa por hora.
Entregable	Proforma en Word: evaluación inicial, adecuación y control mensual con subtotal sin IVA, IVA y total.

1. **Datos del cliente**
   Ventas del ejercicio anterior sin IVA, trabajadores, sector, actividades y encargados.
2. **Tres métodos**
   Revise el resultado por volumen de negocio, por volumen de tratamiento y por horas.
3. **Decida**
   Lea la mediana, el rango y las advertencias. Elija el método base; considere paquetes o bolsa de horas.
4. **Proforma**
   Marque servicios, revise valores, agregue la multa estimada de la herramienta 03 y complete condiciones y firma.
5. **Neto real**
   Revise, solo para usted, lo que recibirá después de las retenciones.

ERROR FRECUENTE

Ofrecer en la proforma «implementación completa» como si fuera tarea del DPD. Describa la adecuación como asesoría con entregables y deje claro que la empresa implementa (capítulo 3).

9.3 Herramienta 03 · Nivel de madurez

Qué es	Diagnóstico de 39 preguntas en 12 dominios, con índice ponderado de 0 a 4, radar, plan de acción priorizado y estimación de la multa con la metodología de la SPDP.
Por qué	Sin punto de partida medible no hay plan defendible ni forma de demostrar avance. El reglamento de multas usa la madurez en el cumplimiento como variable de cálculo.
Según el caso	Siempre al inicio y cada año. En una microempresa con pocos tratamientos puede aplicarse en una sola reunión; en una mediana o grande, tras el mapeo del capítulo 6 y entrevistas por área.
Entregable	Informe de diagnóstico (Word) y tabla de resultados (Excel).

1. **Mapeo**
   Complete la ficha de perfil y la agenda de entrevistas (capítulo 6).

2 **Cuestionario con evidencia**

Puntúe de 0 a 4. Sin documento, no es 3. N/A solo si el punto no aplica, y justifíquelo.

3 **Resultados**

Índice ponderado (los dominios críticos pesan el doble), radar y plan de acción con la herramienta que cierra cada carencia.

4 **Impacto económico**

Ingresos del ejercicio anterior, categoría de infracción y seriedad: multa sin acción y con plan.

5 **Apetito al riesgo**

Capacidad de pérdida y tolerancia de la gerencia.

6 **Informe**

Copie a Word, revise y firme.

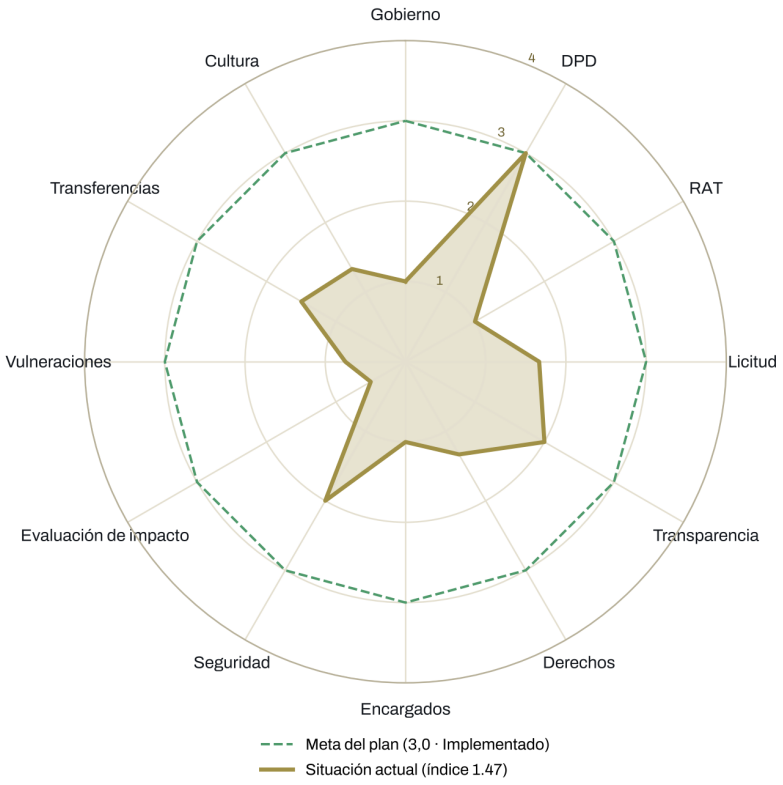


Figura 9. Radar de madurez del ejemplo ficticio (índice 1,47, nivel Inicial) frente a la meta del plan (3,0).

Variable	Qué mide	Cómo la obtiene la herramienta
VDN	Volumen de negocio del ejercicio anterior	Ingresos menos impuestos relacionados (LOPDP art. 73)
RDM	Rango legal de la categoría	Leve 0,1 %-0,7 %; grave 0,7 %-1 %
PDI	Grado de madurez en el cumplimiento	Interpretación del portafolio: (1 – índice / 4) × 100
CDI · SDI	Categoría y seriedad de la infracción	Fórmulas MPRIV-1 de la Res. SPDP-SPD-2025-0022-R
Multa	Monto estimado	CDI × SDI, acotada al mínimo y máximo legal

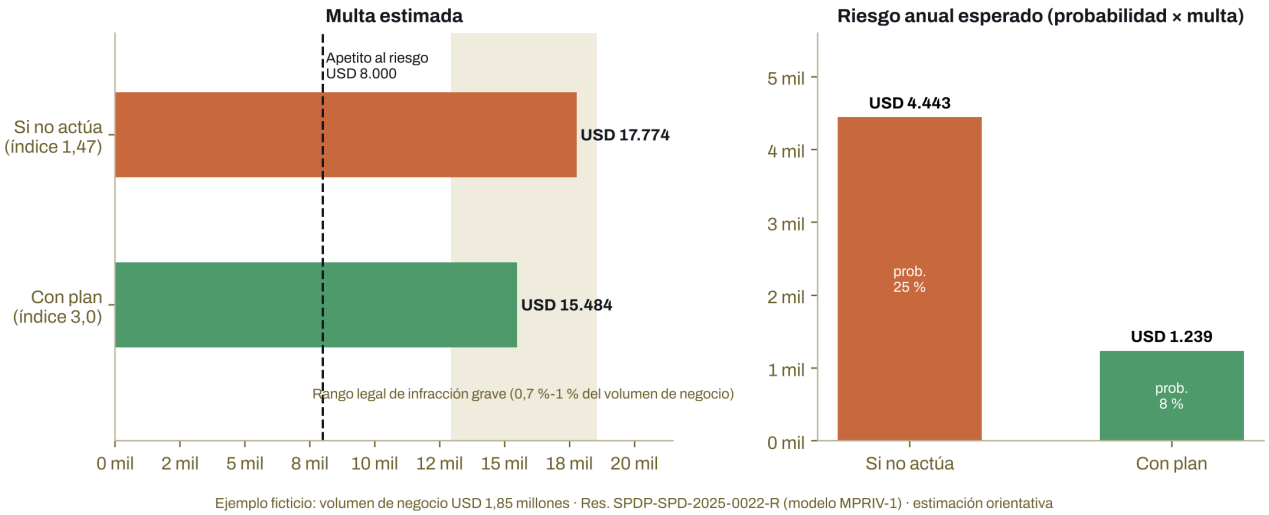


Figura 10. Multa estimada y riesgo anual esperado del ejemplo ficticio, sin acción y con plan, frente al apetito al riesgo.

ATENCIÓN

Es una **estimación orientativa**, no una liquidación. Las fórmulas provienen de un resumen profesional de la resolución; el sentido del PDI y los pesos son interpretación del portafolio.

9.4 Herramienta 04 · Registro de actividades de tratamiento

Qué es	Plantilla Excel y asistente web para documentar cada actividad con el contenido mínimo del art. 38 RGLOPDP, con control automático del estado y del riesgo.
Por qué	Es el inventario obligatorio y la base de la gran escala, la evaluación de impacto, la política y los contratos.
Según el caso	Obligatorio con 100 o más trabajadores y, con menos, si el tratamiento implica riesgo, no es ocasional o incluye categorías especiales (arts. 38 y 39 RGLOPDP). En la práctica, imprescindible siempre: sin RAT no funcionan las herramientas 05, 07 y 08.
Entregable	RAT en Excel aprobado por la gerencia, con hoja del encargado si aplica.

1. **¿Está obligada?**
   Responda las preguntas de obligatoriedad, cada una con su ayuda normativa.
2. **Una actividad por fila**
   Misma finalidad y base. Nómina y publicidad son actividades distintas.
3. **Catálogo**
   Elegir una actividad del catálogo sugiere finalidades, datos y bases que el DPD valida con el dueño del proceso.
4. **Mínimo legal y buenas prácticas**
   Los nueve elementos del art. 38 llevan a «Mínimo cumplido»; las buenas prácticas, a «Completo».
5. **Encargados y destinatarios**
   Registre por separado quién trabaja para la empresa y a quién se comunican datos (capítulo 8).
6. **Revisión**
   Fecha de revisión anual o ante cambios; agregue el puntaje de la herramienta 05.

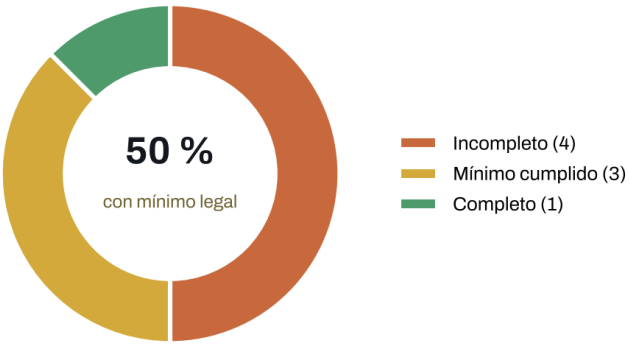


Figura 11. Estado del RAT del ejemplo ficticio: 8 actividades, 50 % con el mínimo legal cumplido.

ERROR FRECUENTE

Agrupar todo en «Gestión de clientes». Mezcla finalidades con bases y plazos distintos y vuelve imposible justificar cada una.

9.5 Herramienta 05 · Evaluación de gran escala

Qué es	Asistente instructivo que califica cada tratamiento: casos de calificación directa (RGLOPDP art. 4 num. 7 y art. 14 de la Res. SPDP-SPD-2026-0005-R) y Modelo Técnico de Gran Escala con seis variables y umbral de 6 puntos.
Por qué	Si un tratamiento es de gran escala, el DPD y la evaluación de impacto previa son obligatorios, el cálculo debe constar en el RAT, se audita cada 12 meses y se elabora un informe anual. Es la forma objetiva de responder «¿debo tener DPD?».
Según el caso	Siempre después del RAT: toda organización debe evaluar si sus tratamientos son de gran escala (art. 4 de la resolución). Decisiva cuando hay biométricos, cámaras, salud, menores, crédito o courier. Recalcule cada año y ante cambios sustanciales.
Entregable	Informe de gran escala firmado, con la evidencia de cada variable, y columnas para el RAT.

Variable	Qué dato pedir	Puntos
Titulares	Personas únicas del tratamiento en 12 meses	1 a 4
Volumen	Tipos de datos por persona (campos del formulario o la base)	0,5 a 3
Categorías	Datos sensibles, NNA, salud, discapacidad, penales o grupos vulnerables	0,5 a 3
Frecuencia	Puntual, periódica o continua	0,5 a 2
Permanencia	Tiempo de uso activo (sin archivo ni bloqueo)	0,5 a 2
Alcance	Local, nacional, o global y transfronterizo	1 a 3

1. **Pida la información**
   Envíe la solicitud de información de la herramienta: conteos, campos, documentos, plazos de uso y cobertura.
2. **Paso A: calificación directa**
   Salud, biométricos, geolocalización, crédito, NNA, videovigilancia de espacios públicos, transferencias sistemáticas o courier.
3. **Paso B: seis variables**
   Cada una con qué pedir, a quién, cómo contar y cómo explicar. Registre la fuente.

4 **Lea y documente**

6 puntos o más: gran escala. Copie el informe a Word y las columnas al RAT; use el guion para la gerencia.

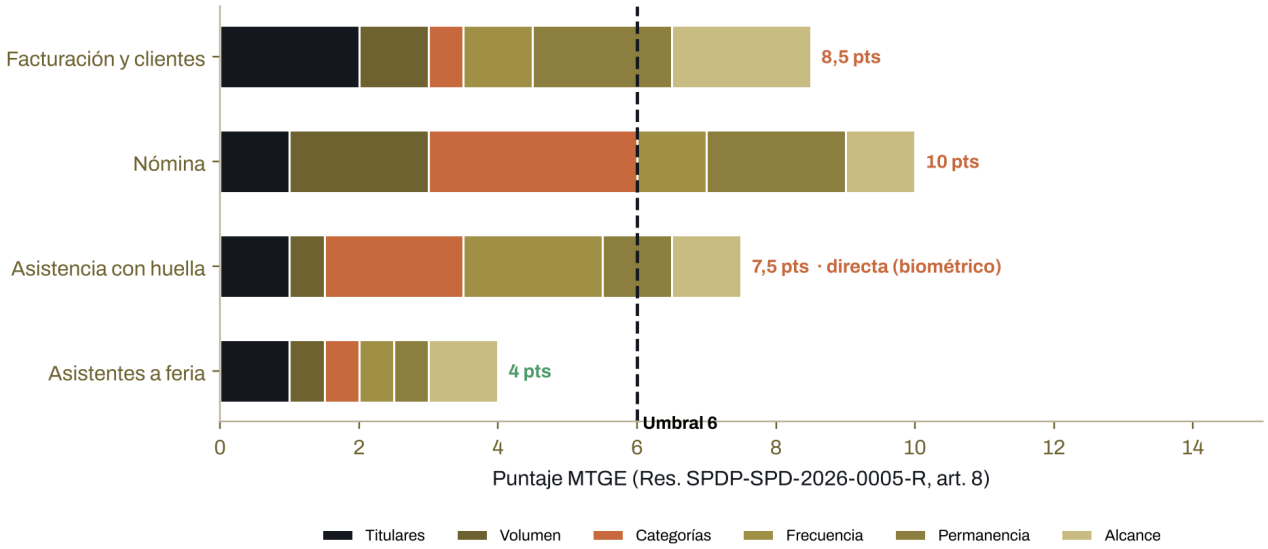


Figura 12. Puntaje MTGE de cuatro tratamientos del ejemplo ficticio. Tres superan el umbral; la asistencia con huella además es de calificación directa.

ATENCIÓN

El umbral se alcanza con facilidad: un tratamiento con pocos datos básicos suma 6,5 puntos si es prolongado y nacional. Aplique el modelo como está, documente cada dato y, si el resultado parece desproporcionado, el responsable puede consultar a la SPDP; su respuesta es obligatoria para quien consulta (RGLOPDP art. 53).

CÓMO DECIRLO AL CLIENTE

«La Superintendencia mide la gran escala con seis factores. Su facturación suma 8,5 puntos y el límite es 6. No es una sanción: significa que la ley le exige un delegado registrado, una evaluación de riesgos previa y una auditoría anual.»

9.6 Herramienta 06 · Interés legítimo

Qué es	Asistente de cinco pasos para la evaluación de ponderación de la Res. SPDP-SPD-2025-0041-R: si puede invocarse, el interés y sus características, la necesidad, la ponderación con los derechos del titular, y el resultado con su registro.
Por qué	El interés legítimo solo vale si existe una evaluación de ponderación previa, motivada, documentada y disponible para la SPDP y los titulares. Omitirla es infracción grave. Además, la resolución lo limita a cinco supuestos y fija prohibiciones.
Según el caso	Solo en el sector privado y cuando el RAT registra el interés legítimo como base: mercadotecnia directa a clientes, prevención de fraude y lavado de activos, comunicación dentro de un grupo empresarial, seguridad de redes y videovigilancia de seguridad sin audio. Repítala cada año o cuando cambien la finalidad, los datos o el riesgo.
Entregable	Informe de ponderación firmado y fila del registro de evaluaciones para el RAT.

1 **¿Puede invocarse?**

Sector privado, supuesto admisible con sus condiciones y cuatro prohibiciones: categorías especiales, perfiles con efectos jurídicos, niñas, niños y adolescentes, tratamiento masivo o reutilización incompatible.

2 **El interés**

Quién lo tiene, qué busca y por qué no basta otra base. Valore las cuatro características: lícito, real y concreto, proporcional y coherente con las expectativas razonables.

3 **Necesidad**

Indispensable, sin alternativa menos intrusiva, con datos mínimos y plazo definido.

4 **Ponderación**

Peso del interés frente al impacto en el titular; las salvaguardas reducen el impacto. Los puntajes son criterio propio: la conclusión se motiva por escrito.

5 **Resultado y registro**

Prevalece, prevalece con salvaguardas o no prevalece. Verifique la política de privacidad y el canal de oposición, y fije la revisión anual.

CÓMO DECIRLO AL CLIENTE

«Para enviar ofertas a sus clientes sin pedirles autorización, la ley le exige demostrar por escrito que su interés comercial no pesa más que la privacidad de ellos. Este documento lo demuestra, y cada correo debe permitir darse de baja con un clic.»

ERROR FRECUENTE

Usar el interés legítimo como comodín cuando no se obtuvo el consentimiento. Si el caso no está entre los supuestos admitidos o la ponderación no favorece a la empresa, la base debe ser otra.

9.7 Herramienta 07 · Evaluación de impacto

Qué es	Asistente de seis pasos alineado con la Guía v2 de la SPDP: necesidad, descripción, necesidad y proporcionalidad, establecimiento del contexto, matriz de riesgos con medidas, y conclusión e informe con el contenido del art. 32 RGLOPDP.
Por qué	Es obligatoria y previa en los casos del art. 42 LOPDP y cuando el tratamiento es de gran escala (Res. SPDP-SPD-2026-0005-R art. 12).
Según el caso	Solo para tratamientos de alto riesgo: los que la herramienta 05 califica de gran escala, perfiles automatizados, biométricos, inteligencia artificial o datos de NNA. No la aplique a todo el RAT; recomiéndela ante nuevas tecnologías aunque no sea obligatoria.
Entregable	Informe de evaluación de impacto y matriz de riesgos aprobados por la gerencia.

1 **¿Es obligatoria?**

Supuestos del art. 42, gran escala y normativa especial.

2 **Descripción**

Finalidades, operaciones, datos, titulares, sistemas, flujos y terceros.

3 **Necesidad y proporcionalidad**

¿Hay una alternativa menos invasiva? ¿Se minimizan los datos?

4 **Contexto**

Cinco factores de impacto de la guía v2 (categorías especiales, vulnerabilidad, número de titulares, naturaleza de la afectación, volumen por titular), derechos en juego, periodo de la probabilidad, método y capacidad de riesgo.

5 **Riesgos y medidas**

Por escenario: derechos afectados, impactos primarios y secundarios, impacto y probabilidad (1 a 5) con su justificación, medidas y riesgo residual.

6 **Conclusión**

Umbral de aceptación, dictamen y plan. La gerencia decide; el DPD asesora y supervisa.

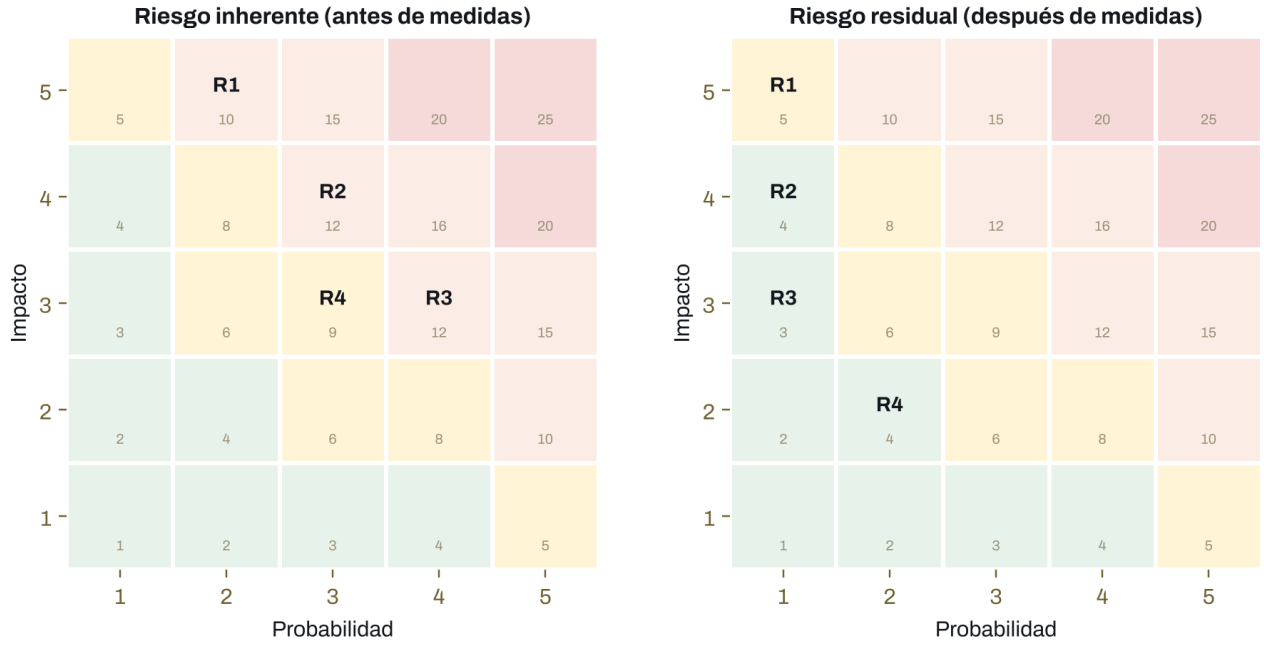


Figura 13. Matriz de riesgo del ejemplo (control de asistencia con huella): las medidas llevan los riesgos de nivel Alto a Medio y Bajo.

Cómo determinar el impacto sobre los derechos, paso a paso

1. **Fije los criterios antes de valorar.** Los cinco factores del contexto dan un piso de impacto: ningún escenario debería valorarse por debajo sin explicarlo.
2. **Identifique los derechos en juego.** No solo la privacidad: trabajo, salud, igualdad, patrimonio, interés superior de niñas, niños y adolescentes.
3. **Describa el escenario.** Dato en riesgo, amenaza y vulnerabilidad en una frase concreta.
4. **Separe impactos primarios y secundarios.** Lo que sufre el titular directamente y lo que provocan terceros después.
5. **Justifique cada valor.** Antecedentes, datos del sector y controles existentes. La guía v2 llama «ruido» a la estimación sin fundamento.
6. **Decida y vuelva a medir.** Medidas, riesgo residual y comparación con el umbral; repita cuando cambie el tratamiento.

CONCEPTO CLAVE

Riesgo inherente es el riesgo antes de las medidas; **riesgo residual**, el que queda después. Quien implementa las medidas es la empresa; el DPD verifica que el residual quede por debajo del umbral aceptado.

9.8 Herramienta 08 · Kit de plantillas

Qué es	Generador de documentos: política de privacidad, avisos, contrato de encargo, cláusulas de consentimiento, cláusulas por tipo de contrato (laboral, por cargo o rol, encargo, transferencia y corresponsables), designación del DPD, política interna, formulario y procedimiento de derechos, registro de medidas de seguridad, plan e informe de supervisión, evaluación de diseño y por defecto y plan de capacitación.
Por qué	Cumple el deber de información (art. 12 LOPDP), formaliza a los encargados (art. 41 RGLOPDP; su falta es infracción grave) y documenta consentimientos y la designación del DPD.
Según el caso	Siempre, pero después del RAT. Elija solo las plantillas necesarias: una empresa sin encargados no necesita contratos de encargo; el consentimiento solo cuando es la base. Los documentos son borradores que la gerencia aprueba.
Entregable	Documentos en Word con firma de responsabilidad.

1. **Datos generales**
   Razón social, RUC, correo institucional de atención al titular, datos del DPD.
2. **Política desde el RAT**
   Finalidad, base, plazo, destinatarios y transferencias de cada actividad.
3. **Avisos por punto de recolección**
   Uno por formulario, letrero o canal.
4. **Contratos de encargo**
   Uno por cada encargado del RAT (capítulo 8).
5. **Aprobación**
   La gerencia revisa, aprueba y publica; el DPD verifica que se usen.
6. **Operación y supervisión**
   Política interna al personal, procedimiento y registro de derechos, registro de medidas de seguridad; al cierre del periodo, plan e informe de supervisión.

ERROR FRECUENTE

Pedir consentimiento para todo «por si acaso». Si el titular lo revoca y el tratamiento sigue siendo necesario, la cláusula queda engañosa.

9.9 Herramienta 09 · Kit de vulneraciones

Qué es	Protocolo de respuesta, bitácora y modelos de comunicación del encargado al responsable, a la SPDP y a los titulares, con calculadora de plazos y evaluación orientativa del riesgo.
Por qué	La notificación es obligatoria y con plazos cortos: el encargado comunica al responsable en máximo 2 días y el responsable notifica a la SPDP en el término de 5 días por el SISPDP; desde mayo de 2026, también al CSIRT.
Según el caso	El protocolo, siempre y antes de cualquier incidente. El asistente, en las primeras horas de un incidente; si el cliente llega con un incidente en curso, empiece por aquí aunque no tenga nada más.
Entregable	Protocolo aprobado, bitácora y notificaciones con constancia.

1. **Contener**
   Aislar, revocar accesos, recuperar lo enviado por error. Registrar la hora de constancia.
2. **Evaluar**
   Causales del art. 24 RGLOPDP y factores de gravedad.

3 **Notificar**

El responsable notifica; el DPD asesora y coordina como punto de contacto.

4 **Documentar**

Bitácora completa, se notifique o no.

ATENCIÓN

El plazo exacto de comunicación a los titulares y el canal del CSIRT son **puntos abiertos**: verifíquelos en el texto oficial.

CAPÍTULO 10

Áreas de tratamiento: cómo explicarlas

El RAT organiza las actividades por macroprocesos; el diagnóstico de madurez, por dominios de obligaciones. El DPD debe saber explicar ambas lecturas.

10.1 Macroprocesos del RAT

Macroproceso	Actividades típicas	Datos frecuentes	Base habitual	A vigilar
Gestión de personas	Selección, nómina, asistencia, salud ocupacional	Identificación, bancarios, cargas (NNA), salud, biométricos	Obligación legal; contrato	Biométricos (gran escala directa); salud
Clientes y ventas	Facturación, atención, cobranza, fidelización	Identificación, contacto, financieros	Contrato; obligación legal	Publicidad sin base
Servicio principal	Historias clínicas, gestión académica, pólizas	Salud, NNA, financieros	Contrato; obligación legal	Gran escala directa
Proveedores y compras	Contratación, pagos	Contacto de personas naturales	Contrato	Encargados sin contrato
Marketing	Publicidad, redes, eventos	Contacto, imagen, preferencias	Consentimiento; interés legítimo ponderado	Perfiles; listas sin base
Seguridad física	Videovigilancia, control de acceso	Imagen, biométricos	Interés legítimo	Vía pública (gran escala); plazos
Tecnología	Correo, nube, respaldos	Todos	La de cada actividad	Encargados en el exterior; vulneraciones
Legal y cumplimiento	Derechos, requerimientos de autoridades	Identificación, expedientes	Obligación legal	Plazos de respuesta

10.2 Dominios del diagnóstico de madurez

Dominio	Qué significa	Nivel 3 (Implementado)	Herramienta
Gobierno	La dirección asume la protección de datos	Política interna aprobada, roles asignados, reporte periódico	03
DPD (crítico)	La figura del DPD está analizada y, si corresponde, designada	Gran escala evaluada; DPD registrado y con acceso a la dirección	05, 08
RAT (crítico)	La organización sabe qué datos trata	RAT con mínimo legal, revisado, con puntaje MTGE	04, 05
Licitud (crítico)	Cada tratamiento tiene su base	Bases por actividad; consentimientos verificables	04, 08
Transparencia	Los titulares saben qué se hace con sus datos	Política y avisos en cada punto de recolección	08
Derechos	Los titulares pueden ejercer sus derechos	Canal, procedimiento y registro con plazos	08
Encargados (crítico)	Los proveedores que tratan datos están controlados	Inventario de encargados y contratos firmados	04, 08

Dominio	Qué significa	Nivel 3 (Implementado)	Herramienta
Seguridad (crítico)	Los datos están protegidos según su riesgo	Análisis de riesgos, accesos por rol, respaldos probados	07
Evaluación de impacto	Los tratamientos de alto riesgo se evalúan antes	Evaluaciones previas; privacidad desde el diseño	05, 07
Vulneraciones (crítico)	La organización responde en plazo	Protocolo, canal interno, bitácora	09
Transferencias	Las comunicaciones y transferencias tienen base y garantías	Encargo y transferencia distinguidos; garantías documentadas	04
Cultura	El personal sabe proteger datos	Capacitación al ingreso y periódica	Plan de capacitación

CONCEPTO CLAVE

Los dominios **críticos** pesan el doble en el índice. Es criterio propio del kit: la SPDP no ha emitido un modelo oficial de madurez.

CAPÍTULO 11

El informe a la gerencia

Primero se entrega el informe de evaluación general, con todos sus soportes; después se presenta en una reunión breve, centrada en decisiones que toma la gerencia.

11.1 Estructura del informe de evaluación general

Sección	Contenido	Fuente
1. Resumen ejecutivo (1 página)	Nivel de madurez, tres hallazgos, exposición económica y tres decisiones solicitadas	03
2. Alcance y metodología	Mapeo, procesos evaluados, entrevistas, documentos revisados y normas aplicadas	Cap. 6
3. Resultado de madurez	Índice, radar y puntaje por dominio	03
4. Inventario de tratamientos	Actividades, estados, encargados y destinatarios	04
5. Gran escala	Tratamientos de gran escala y obligaciones que activan	05
6. Riesgos	Tratamientos que requieren evaluación de impacto y riesgo residual	07
7. Exposición económica y apetito al riesgo	Multa estimada sin acción y con plan	03
8. Plan de acción	Acciones con responsable de la empresa, fecha y costo	03
9. Decisiones solicitadas	Aprobación del plan, presupuesto, designación de DPD, aprobación de documentos	—
Anexos	RAT, informes de gran escala y de impacto, matriz de soportes	04 a 07

11.2 Matriz de soportes

Dato del informe	Soporte o evidencia	Quién lo provee
Índice de madurez	Cuestionario con evidencias; documentos revisados	DPD con cada área
Volumen de negocio	Estado de resultados o declaración de impuesto a la renta	Contabilidad
Actividades y estados	RAT aprobado	Dueños de procesos
Tratamientos de gran escala	Informe de la herramienta 05 con conteos y evidencia	Sistemas y dueños de procesos
Encargados sin contrato	Proveedores con acceso a datos y contratos vigentes	Compras o legal
Transferencias	Destinatarios, bases y garantías	Legal, sistemas
Riesgos residuales	Evaluaciones de impacto	DPD y sistemas
Apetito al riesgo	Acta o correo de la gerencia	Gerencia
Incidentes y capacitación	Bitácora y registros de asistencia	DPD, talento humano

11.3 La presentación oral (20 minutos)

1. **Un mensaje por gráfico**
   Radar (dónde estamos), multa estimada (cuánto arriesgamos), plan (qué hacemos).
2. **Hallazgos en lenguaje de negocio**
   «El proveedor de nómina no tiene contrato de encargo: es una infracción grave».
3. **Decisiones concretas**
   Tres decisiones, cada una con costo, responsable de la empresa y fecha.
4. **Acta**
   Registre lo decidido: es evidencia de responsabilidad proactiva.

CÓMO DECIRLO AL CLIENTE

«Hoy estamos en nivel Inicial y tres de sus tratamientos son de gran escala. Les pido aprobar tres decisiones: el plan de seis meses, la firma de los contratos de encargo y la designación del delegado. Yo los acompaño y verifico; la ejecución es de su equipo.»

11.4 Carpeta de evidencias

Carpeta	Contenido
01-Propuesta	Proforma aceptada, contratos de servicio, confidencialidad y encargo
02-Diagnóstico	Ficha de mapeo, informe de madurez, matriz de soportes
03-RAT	RAT vigente y versiones anteriores; inscripción en el Registro Nacional
04-Gran escala	Informes de cálculo del MTGE y su evidencia
05-Riesgos	Evaluaciones de impacto y constancias de presentación
06-Documentos	Política, avisos, contratos de encargo firmados, consentimientos, designación del DPD
07-Incidentes	Protocolo, bitácora, notificaciones y constancias del SISPDP
08-Gerencia	Informes, actas y decisiones

CAPÍTULO 12

Control y mejora continua

El cumplimiento se degrada si nadie lo mide. El control es la función propia del DPD: supervisar, medir e informar.

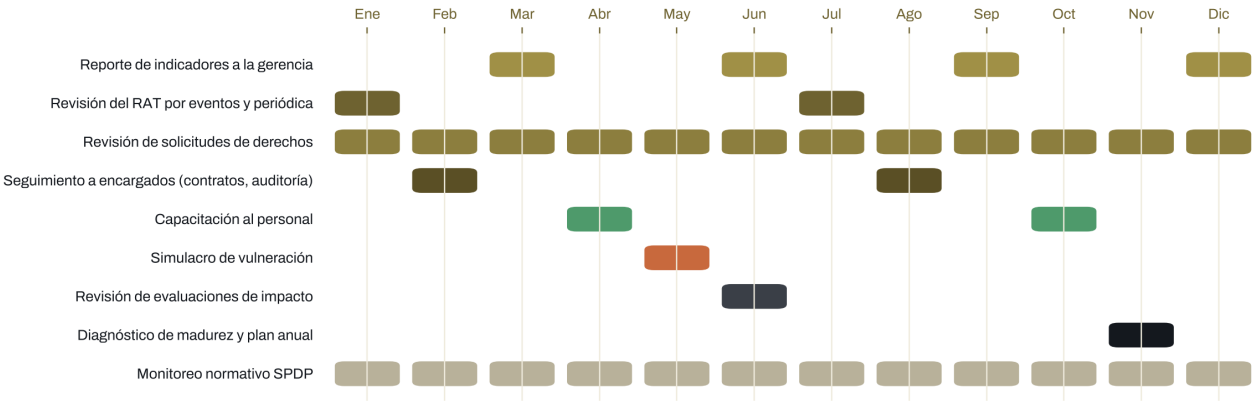


Figura 14. Calendario anual orientativo de actividades del DPD (criterio propio).

Indicador	Fórmula	Meta orientativa*
Actividades con mínimo legal	Actividades en Mínimo cumplido o Completo / total del RAT	100 %
Tratamientos con puntaje MTGE vigente	Actividades con cálculo de menos de 12 meses / total	100 %
Encargados con contrato	Encargados con contrato / total de encargados	100 %
Solicitudes de derechos en plazo	Respondidas en plazo / recibidas	100 %
Personal capacitado	Capacitados en el año / total de personal	90 % o más
Vulneraciones notificadas en plazo	Notificadas en plazo / notificables	100 %
Índice de madurez	Resultado anual de la herramienta 03	2,8 o más

* Criterio propio; ajustar con la gerencia.

CAPÍTULO 13

Normas ISO para el ejercicio del DPD

La LOPDP no exige certificaciones ISO. Pero las normas ISO ofrecen métodos probados para cumplirla y demostrarlo.

QUÉ DICE LA NORMA

La SPDP tiene competencia para emitir normativa sobre códigos de conducta y mecanismos de certificación (LOPDP art. 76 num. 5); su plan regulatorio prevé un reglamento de certificaciones y sellos. Verifique su estado antes de ofrecer una certificación como prueba de cumplimiento.



Figura 15. Normas ISO por nivel de prioridad para el ejercicio del DPD (criterio propio).

Norma	Qué es	Relación con la LOPDP
ISO/IEC 27701:2025	Sistema de gestión de la privacidad; desde la edición de octubre de 2025 es independiente de ISO/IEC 27001	Estructura todo el programa: roles, RAT, derechos, encargados, evaluación de impacto
ISO/IEC 27001:2022	Sistema de gestión de seguridad de la información	Medidas técnicas y organizativas (art. 38 num. 9 RGLOPDP) y análisis de riesgos
ISO/IEC 29100	Marco de privacidad: terminología, actores, principios	Lenguaje común con TI y auditores
ISO/IEC 29134	Directrices para la evaluación de impacto en la privacidad	Metodología para la herramienta 07

Recomendadas y según el caso	Cuándo usarla
ISO/IEC 27002 · 27005 · ISO 31000	Controles de seguridad y gestión de riesgos
ISO/IEC 27035	Gestión de incidentes (herramienta 09)
ISO/IEC 29151 · 27018	Controles de datos personales; nube pública
ISO/IEC 29184 · 27560	Avisos de privacidad y registros de consentimiento
ISO/IEC 42001	Inteligencia artificial
ISO 22301	Continuidad del negocio

1 **Meses 0 a 6: cumplimiento LOPDP**

Herramientas del kit, con ISO/IEC 29100 y 29134 como guía metodológica.

2 **Meses 6 a 18: sistema de gestión**

ISO/IEC 27701:2025 sobre lo construido; ISO/IEC 27001 si se necesita certificar seguridad.

3 **Certificación**

Solo cuando la exijan clientes, licitaciones o el sector.

CAPÍTULO 14

Recomendaciones para el ejercicio del DPD en Ecuador

Aspectos que no están en las herramientas, pero que determinan la calidad y la seguridad jurídica del ejercicio profesional.

Aspecto	Recomendación
Rol claro por escrito	Toda propuesta y contrato debe decir qué hace el DPD y qué hace la empresa (capítulo 3).
Independencia	No decida finalidades ni administre los sistemas que supervisa; no acumule cargos incompatibles.
Requisitos y registro	Verifique los requisitos vigentes (Res. SPDP-SPD-2025-0028-R; RGLOPDP art. 55).
Su propio cumplimiento	Como DPD externo es encargado de los datos de sus clientes: contrato de encargo y confidencialidad.
Uso de inteligencia artificial	Use datos anonimizados o seudonimizados y documente la evaluación del proveedor.
Firma de responsabilidad	Firme solo lo que verificó; cada entregable lleva bloque de firma.
Actualización normativa	Revise cada mes las resoluciones y consultas absueltas de la SPDP y actualice la matriz del kit.
Límites del servicio	Deje por escrito lo que no incluye (pruebas técnicas, implementación) y recomiende especialistas.
Seguro y honorarios	Evalúe un seguro de responsabilidad profesional: el DPD responde administrativa, civil y penalmente (LOPDP art. 49).

CAPÍTULO 15

Contraste con las guías de la SPDP

El kit se revisó contra la Guía v2 de gestión de riesgos y evaluación de impacto y la Guía de protección de datos desde el diseño y por defecto, para que ningún paso quede en el aire.

15.1 Guía v2 de gestión de riesgos (Res. SPDP-SPD-2026-0012-R)

El capítulo I es obligatorio y rechaza el cumplimiento «en el papel»: listas de chequeo, niveles sin fundamento e informes extensos sin sustancia. Exige justificar cada valor de entrada. El capítulo II, referencial, ordena cinco etapas.

Etapa	Qué pide	Dónde lo cubre el kit
1. Contexto	Criterios de impacto en derechos, probabilidad en un lapso definido, capacidad y tolerancia	07, pestaña Contexto (nueva)
2. Identificación	Datos (RAT), amenazas, vulnerabilidades jurídicas, de grupos, organizacionales y técnicas; escenarios	04 y 07
3. Análisis	Modelo cualitativo calibrado o cuantitativo; justificación de cada valor	07 (justificación obligatoria por riesgo); 03 para multas
4. Evaluación	Comparar con la aceptación y decidir	07, umbral y dictamen
5. Tratamiento	Medidas, responsables y plazos; declaración de aplicabilidad	07; la declaración de aplicabilidad queda pendiente

15.2 Guía de diseño y por defecto (Res. SPDP-SPD-2025-0040-R)

Desarrolla el art. 39 LOPDP: los riesgos se consideran desde la planificación y, por defecto, el sistema trata solo los datos necesarios. Propone ocho principios DevPrivOps: minimizar, ocultar, separar, abstraer, informar, controlar, cumplir y demostrar, y una escala de madurez de 0 a 3 por principio sobre las actividades del RAT.

- Los ocho principios tienen ahora un control equivalente en el catálogo de medidas de la herramienta 07.
- El servicio S24 del catálogo aplica la guía a proyectos nuevos: intervenga antes de que la empresa firme con el proveedor.
- La madurez por principio y actividad aún no está en la herramienta 03: la SPDP anunció una guía de controles y madurez.

15.3 Recursos pendientes

Algunos textos oficiales no pudieron leerse completos. La lista está en **docs/recursos-pendientes.md** del kit; los más importantes son el texto íntegro de la Res. SPDP-SPD-2025-0041-R con su Anexo 1, las etapas 4 y 5 y el anexo con el formato de evaluación de impacto de la guía v2, y la Res. SPDP-SPD-2026-0040-R de vulneraciones.

> **ATENCIÓN**
> Hasta obtener esos textos, las herramientas 06 y 07 se apoyan en resúmenes fieles y en escalas de criterio propio. Dígalo en el informe al cliente.

ANEXOS

Anexos

Anexo A · Lista de verificación de la primera visita

Verificar	Sí / No / Observación
¿Política de privacidad publicada?	
¿Formularios web con aviso?	
¿Cámaras? ¿Con letrero? ¿Captan la vía pública?	
¿Reloj biométrico o GPS?	
¿Proveedores con acceso a datos (nómina, contador, nube)?	
¿Contratos de encargo?	
¿Listado de bases de datos o RAT?	
¿Incidentes previos?	
¿Solicitudes de acceso o eliminación?	
¿Ya evaluó si algún tratamiento es de gran escala?	
¿Número de trabajadores e ingresos del ejercicio anterior?	

Anexo B · Guion de entrevista por área

1. ¿Qué procesos realiza su área? ¿Cuál es el más frecuente?
2. En cada proceso, ¿qué información de personas se solicita? ¿En qué formulario o canal?
3. ¿Para qué se usa esa información? ¿Se usa también para algo más?
4. ¿Dónde se guarda: sistema, nube, correo, hoja de cálculo, papel?
5. ¿Cuántas personas distintas hay en esa base en los últimos 12 meses?
6. ¿Quién tiene acceso dentro y fuera de la empresa? ¿Ese proveedor trabaja para ustedes o usa los datos para lo suyo?
7. ¿Se envía a alguna entidad pública o privada? ¿Alguna está fuera del Ecuador?
8. ¿Cuánto tiempo se usa y cuánto se conserva? ¿Quién decide cuándo se elimina?
9. ¿Se toman decisiones automáticas o se elaboran perfiles?
10. ¿Ha ocurrido algún incidente con esos datos?

Anexo C · Puntos que el DPD debe verificar en el texto oficial

Tema	Estado en el kit
Plazo de comunicación de vulneraciones a los titulares	La doctrina cita 3 días (art. 46 LOPDP); verificar.
Canal y plazo de notificación al CSIRT	Reforma del art. 43 (mayo 2026); verificar.
Anexo I de la Res. SPDP-SPD-2025-0022-R	Fórmulas de un resumen profesional; PDI y pesos interpretados.
Alcance de «otros datos sensibles» (Res. 2026-0005 art. 14.1)	Podría calificar directamente todo tratamiento con datos sensibles.
Alcance «transfronterizo» en el MTGE	Precisar si basta el almacenamiento fuera del país.

Tema	Estado en el kit
Mecanismos de la Res. SPDP-SPD-2026-0004-R	Leer la norma completa e incorporarla a las herramientas 04 y 08.
Retenciones de IVA y renta	Verificar la tabla vigente del SRI.
Artículos de supuestos y prohibiciones de la Res. SPDP-SPD-2025-0041-R	Leer el texto oficial y su Anexo 1; confirmar si existe ponderación simplificada para riesgo medio.
Anexo con el formato de evaluación de impacto de la guía v2	Contrastar el informe de la herramienta 07.
Reglamento de certificaciones y sellos	Verificar si fue expedido.

MANTENIMIENTO DEL KIT

El kit se mantiene en un repositorio con una matriz de base legal y un historial de versiones. Cada actualización normativa se registra allí y se refleja en las herramientas y en esta guía.